

# Navy Enterprise Inheritance Guide



## Guidance for Risk Management Framework Inheritance in the United States Navy

V1.0

Space and Naval Warfare Systems Command (SPAWAR)

Office of the Chief Engineer (SPAWAR 5.0)  
Information Assurance Technical Authority (IA TA)

4301 Pacific Highway  
San Diego, CA 92110-3127

Abstract: The Department of the Navy supports security inheritance in risk management practices. To date the practice has been ad hoc, site specific, and manual. An enterprise inheritance initiative for authorization and accreditation of Navy systems can enhance opportunities for reciprocity, minimize total costs, and enable transparency for authorized systems. To succeed, the initiative must specify governance, implementation, and assessment requirements.

Distribution authorized to the Department of Defense and U.S. DoD contractors only (Administrative, Operational Use) September 2013.  
Other requests shall be referred to the Commanding Officer, SSC Pacific, San Diego, California 92152-5001.

**Record of Changes**

Table 1 is used to record revisions to this document. The date, revision number, and description of change for each revision are noted in the table.

**Table 1. Revision History**

| <b>Date</b> | <b>Author</b> | <b>Revision Number</b> | <b>Change Code</b> | <b>Title or Brief Description of Revision</b> |
|-------------|---------------|------------------------|--------------------|-----------------------------------------------|
|             |               |                        |                    |                                               |
|             |               |                        |                    |                                               |
|             |               |                        |                    |                                               |
|             |               |                        |                    |                                               |
|             |               |                        |                    |                                               |
|             |               |                        |                    |                                               |
|             |               |                        |                    |                                               |

**\* A – Added   M – Modified   D – Deleted**

Please direct any comments about this document to the Navy Cyber Security, SPAWAR 58000.

## Navy Enterprise Inheritance Guide (NEIG)

### Signature Page

Navy Information Assurance Technical Authority:



Approval Date: 17 Nov 2017

R. R. Fritzemeier  
Rear Admiral, U.S. Navy  
Chief Engineer  
Space and Naval Warfare Systems Command

**Table of Contents**

|                                                               |    |
|---------------------------------------------------------------|----|
| Record of Changes .....                                       | ii |
| Table of Figures .....                                        | v  |
| List of Tables .....                                          | v  |
| Executive Summary .....                                       | vi |
| 1.0 Introduction.....                                         | 1  |
| 1.1 Guide Layout.....                                         | 2  |
| 1.2 Purpose .....                                             | 2  |
| 1.3 Applicability.....                                        | 2  |
| 2.0 Background.....                                           | 2  |
| 3.0 Risk Management Framework.....                            | 3  |
| 4.0 Inheritance.....                                          | 4  |
| 4.1 Inheritable.....                                          | 5  |
| 4.2 Inherited .....                                           | 5  |
| 4.3 NIST SP 800-53 .....                                      | 5  |
| 5.0 Navy Enterprise Inheritance Governance .....              | 10 |
| 5.1 Roles and Responsibilities .....                          | 11 |
| 5.1.1 DoD CIO and DON CIO.....                                | 11 |
| 5.1.2 Navy Authorizing Official (NAO) .....                   | 12 |
| 5.1.3 Security Controls Assessor (SCA) .....                  | 12 |
| 5.1.4 Common Controls Provider (CCP) .....                    | 12 |
| 5.1.5 Critical Inheritance Provider (CIP) .....               | 14 |
| 5.1.6 Information System Owner (ISO).....                     | 15 |
| 6.0 Identifying and Designating Common Security Controls..... | 15 |
| 6.1 Common Controls Procedures .....                          | 15 |
| 6.2 Conditions and Constraints .....                          | 19 |
| 6.3 Security Plans.....                                       | 19 |
| 7.0 Inheritance and the Risk Management Framework (RMF) ..... | 20 |
| 7.1 RMF Step 1 - System Categorization.....                   | 21 |
| 7.2 RMF Step 2 - Security Controls Selection .....            | 21 |
| 7.3 RMF Step 3 - Implement Security Controls .....            | 27 |
| 7.4 RMF Step 4 - Assess Security Controls.....                | 27 |
| 7.5 RMF Step 5 - Authorize System .....                       | 28 |
| 7.6 RMF Step 6 - Monitor Security Controls.....               | 29 |

|                                                          |     |
|----------------------------------------------------------|-----|
| 8.0 Summary .....                                        | 29  |
| Appendix A - Acronyms .....                              | A-1 |
| Appendix B – References .....                            | B-1 |
| Appendix C – eMASS Associations (Inheritance) .....      | C-1 |
| Appendix D - Inheriting Security Controls in eMASS ..... | D-1 |
| Appendix E – Inheritance Overlay .....                   | E-1 |

### **Table of Figures**

|                                                                                    |    |
|------------------------------------------------------------------------------------|----|
| Figure 1. Three-tiered approach to risk management .....                           | 3  |
| Figure 2. Enterprise Inheritance Common Operational Picture (COP) .....            | 11 |
| Figure 3. AO Relationship to the CCP .....                                         | 13 |
| Figure 4. RMF Step 2e Identify Inheritable Common / Hybrid Security Controls ..... | 24 |

### **List of Tables**

|                                                                               |    |
|-------------------------------------------------------------------------------|----|
| Table 1. Revision History .....                                               | ii |
| Table 2. Common Control Sources .....                                         | 14 |
| Table 3: Inheritance-specific PMO activities to be completed during RMF ..... | 20 |

## Executive Summary

Per the DoD Risk Management Framework (RMF) Knowledge Service, security control inheritance is the “situation in which an information system (IS) or application receives protection from security controls (or portions of security controls) that are developed, implemented, assessed, authorized, and monitored by entities other than those responsible for the system or application.”

Defense Information Systems Agency (DISA) Security Controls Inheritance is a foundational component of the Navy's Risk Management Framework (RMF), Cybersecurity Safety (CYBERSAFE), and other Navy certification efforts. Inheritance provides a means for connected systems to satisfy established security requirements through parent/child relationships with Common Control Providers (CCP). For example, a software application residing on a server would not have the capability to satisfy its Physical/ Environmental (e.g., conditioned power, fire suppression) requirements; using the concept of Inheritance, that system may inherit the status of specific security controls from the facility/location in which the server resides.

This example is simplified - a number of items must be validated, implemented, and agreed to before such a relationship can be formalized. However, an effectively implemented Inheritance Model across the Navy Enterprise can save the Navy millions of dollars as well as expedite resources to the Warfighter.

This document provides guidance for the implementation and management of inheritance across the Navy enterprise, consistent with the Federal, DoD, and NIST RMF strategies, direction, and guidance. This guide provides the Inheritance model, associated reference documentation, roles, and responsibilities of those charged with its implementation, and specific instructions for documenting inheritance relationships through the Enterprise Mission Assurance Support System (eMASS).

The Navy Enterprise Inheritance Model (NEIM) is delineated to maximize reuse and reciprocity across the Navy enterprise. The NEIM is intended to provide all Navy organizations with a model for implementing security control inheritance. It provides detailed processes and procedures for enterprise security controls inheritance for sites, systems, and applications operating in the Navy IT enterprise.

This Inheritance Guide is a product of the Navy's Information Assurance (IA) Technical Authority (TA), intended to specify the security engineering processes required to implement inheritance relationships. Its intent is to improve security postures by standardizing approaches to the implementation and allocation of security controls across major systems in the enterprise. The expected result is a commonality of controls implementation that will reduce complexity, duplication of efforts, and costs across programs and program boundaries.

## 1.0 Introduction

Department of Defense (DoD) Risk Management Framework (RMF) Knowledge Service (KS), defines security control inheritance as “A situation in which an IS or application receives protection from security controls (or portions of security controls) that are developed, implemented, assessed, authorized, and monitored by entities other than those responsible for the system or application; entities either internal or external to the organization where the system or application resides.”

The Department of the Navy (DON) has supported the inheritance of security in risk management since its implementation of the DoD Information Technology Security Certification and Accreditation Process (DITSCAP). Execution of inheritance evolved over time, varying from organization to organization based on disparate interpretations of requirements as well as each organization’s operational requirements and information security architecture. Despite inconsistent processes and procedures (due to individual requirements), organizations realized the benefits of enterprise inheritance. A large enterprise organization can extend its reach by decomposing itself into several security service subsystems, each having discrete responsibilities for a specific subset of the comprehensive set of information assurance (IA)/security controls. This practice distributes requirements across the organization, enables concurrent activities, and maximizes efficiency by avoiding duplicated efforts. In this example, if an application were proposed for inclusion in an enterprise network, the application would be protected by multiple layers of security and controls inherent within the environment, such as the following:

- Security controls applicable to the application itself
- Security controls applicable to the workstation on which the application resides
- Security controls and network-level protection provided by the server farm
- Physical and environmental protections provided by the site where the application deploys
- Security controls provided by external service providers (DISA, et al)
- Security controls provided by the overarching organization itself and its policies.

Software applications (e.g., database applications, Web applications) are especially benefitted by inheritance. Applications hosted by an Information System (IS) are included in the risk management process, since application security is critical to the overall security of the system. Applications may depend on the resources provided by the hosting IS and as such, can take advantage of (i.e., leverage) the security controls provided by the system to help provide a foundational level of protection for the hosted applications. To succeed, this type of inheritance must be applicable and the system must meet inheritance requirements - conditions and constraints (C&C).

Enterprise systems are essentially systems of systems (SOS), supporting a set of common missions and/or business functions. Comprising multiple independent ISs in multiple locations, and sometimes distributed across wide geographic areas, enterprise organizations need an inheritance model designed to maximize efficiency and minimize redundant efforts. Application owners must coordinate with IS owners to ensure that information security and risk management activities are carried out as seamlessly as possible among applications and hosting systems.

The previous Navy model for inheritance did not identify and decompose security control providers and security control recipients with sufficient clarity. Responsibilities for systems and

security providers were not delineated to maximize reuse and reciprocity. With the establishment of the Risk Management Framework (RMF) within the Navy, a formal methodology, processes, and rule-set for implementing and managing inheritance is required as part of the RMF implementation. This model is referred to as the Navy Enterprise Inheritance Model (NEIM).

**Note:** DoD inheritance is defined at the Security Control level and this guide retains those definitions; it must be noted that actual implementation of any inheritance model is actually at the decomposed requirement level or Control Correlation Identifier (CCI).

## **1.1 Guide Layout**

Sections 1 through 4 provide an introduction to inheritance with background and definitions. Section 5 includes Navy enterprise inheritance governance with roles and responsibilities. Section 6 begins the “how to perform inheritance in the Navy” with Identifying and Designating Common Security Controls. Section 7 focuses on inheritance in RMF Steps 1 through 6, with specific detail in Step 2 “Select Security Controls” and sub-step 2e: Identify Inheritable Common / Hybrid Security Controls. Appendices C and D provide the details for how to perform inheritance in the Enterprise Mission Assurance Support System (eMASS).

## **1.2 Purpose**

This document provides guidance for the implementation and management of inheritance across the Navy enterprise. This guidance is consistent with Federal, DoD, and NIST strategy, direction, and guidance for security control inheritance within the DoD Instruction (DoDI) 8510.01, RMF for DoD Information Technology (IT). This document provides all Navy organizations with a model (the NEIM) for implementing security control inheritance. The NEIM provides detailed processes and procedures for enterprise security controls inheritance for sites, systems, and applications operating in the Navy IT enterprise.

This document provides guidance to Program Managers (PM), Acquisition Professionals, System Owners, Information System Security Managers (ISSM), Information System Security Officers (ISSO), Information System Security Engineers (ISSE) and other associated cybersecurity professionals for how to implement and manage security controls inheritance as part of the DoD RMF and the Navy’s RMF processes.

## **1.3 Applicability**

The guidance contained herein is applicable to all United States Navy (USN) General Service (GENSER) (NIPR/SIPR) organizations, sites, systems and applications operating on and connected to the Navy’s IT enterprise. This document provides guidance to support standardization of cybersecurity across the USN and should be tailored as necessary to support the site/program/system under development.

## **2.0 Background**

Inheritance is about how systems and sites work together to share information assurance capabilities, services, and processes. Inheritance refers to situations where security controls, along with their validation results and compliance status, are shared by two or more systems for the purposes of Assessment and Authorization (A&A). Through inheritance, an existing security control and its compliance status extends from an originating IS/facility/site to a receiving IS/facility/site.

Inheritance eliminates the need for the receiving systems/sites to perform duplicative testing, validation, and documentation of inherited controls. The security plan specifically identifies controls inherited from other systems/sites. For inherited controls, validation test results and supporting documentation are maintained by the originating IS/site and are made available to the ISSM of receiving ISs/sites on request.

### 3.0 Risk Management Framework

Inheritance is a key element within the NIST SP 800-37 *Guide for Applying the Risk Management Framework to Federal Information Systems: a Security Life Cycle Approach* structure and the three-tiered approach to risk management detailed in Figure 1. Inheritance will be a critical part of Navy's RMF adoption if the NIST RMF structure and three-tiered approach is going to yield the benefits outlined in SP 800-37.



**Figure 1. Three-tiered approach to risk management**

SP 800-37 outlines several RMF characteristics that would benefit greatly by improved inheritance practices:

- Promotes the concept of near real-time risk management and ongoing IS authorization through the implementation of robust continuous monitoring processes;
- Encourages the use of automation to provide senior leaders the necessary information to make cost-effective, risk-based decisions with regard to the organizational ISs supporting their core missions and business functions;
- Integrates information security into the enterprise architecture and system development life cycle;
- Provides emphasis on the selection, implementation, assessment, and monitoring of security controls, and the authorization of ISs;
- Links risk management processes at the IS level to risk management processes at the organization level through a risk executive (function); and

- Establishes responsibility and accountability for security controls deployed within organizational ISs and inherited by those systems (i.e., common controls).

#### 4.0 Inheritance

To establish a formal methodology and rule-set for implementing and managing inheritance, several complexities must be addressed with the involvement of the entire organization—from senior leaders providing strategic vision and top-level goals and objectives for the Department, mid-level leaders planning and managing acquisition projects, to individuals on the front lines operating the systems supporting the organization’s core missions and business processes.

As an expanded view of the three-tiered approach to risk management, there are Federal, DoD, and component-level elements that impact the selection of controls among each tier. Figure 1 depicts the multi-faceted nature and complexities involved in the NEIM.

Tier 1 represents the DoD perspective, and is where the development of a comprehensive governance structure and DoD-wide risk management strategy (including implementing enterprise inheritance) takes place. The governance structure must be well-defined to successfully standardize how risk will be evaluated.

**Note:** Tier 1 controls/CCIs are considered automatically inheritable by any DoD system, since they are provided/resolved by DoD, usually the DISA.

Tier 2 addresses risk from a mission and business process perspective and is guided by the risk decisions made in Tier 1. Tier 2 activities are closely associated with the Department of Navy (DON) Enterprise Architecture (EA) Security Reference Model (SRM).<sup>1</sup> DON EA SRM provides implementation and compliance measures (e.g., pre-determined parameters for security controls that reflect risk decisions made at the Tier 1 level). For example, there are security controls that have parameters which indicate that DoD elements are automatically compliant with the implementation of a security control, simply by the DoD's definition of specific parameters. DON is to provide security control implementation and compliance measures (e.g., Navy-wide Annual Cyber Training).

**Note:** Tier 2 controls/CCIs are considered automatically inheritable by any DON, Navy, or Marine Corps system.

Tier 3 addresses risk from an IS perspective and is guided by the risk decisions made in Tiers 1 and 2. Risk decisions at Tiers 1 and 2 impact the ultimate selection and deployment of needed safeguards and countermeasures (e.g., security controls) at the IS level. Information security requirements are satisfied by the selection of appropriate management, operational and technical security controls found in the CNSSI 1253 Security Categorization and Control Selection for National Security Systems and the NIST SP 800-53 Current Revision, Security and Privacy Controls for Federal Information Systems and Organizations. The security controls are allocated to the various components of the IS as specific, hybrid, or common controls in accordance with the Navy’s information security architecture and must also be guided by a NEIM to be successful.

---

<sup>1</sup> Federal Enterprise Architecture Reference Models and Segment and Solution Architectures are defined in the OMB Federal Enterprise Architecture (FEA) Program, FEA Consolidated Reference Model Document, Version 2.3, October 2003 and OMB Federal Segment Architecture Methodology (FSAM), January 2009, respectively.

#### 4.1 Inheritable

An inheritable control is a security control capable of providing protection to entities beyond the authorization boundary of the system or site. Security controls are deemed inheritable by ISs or IS components when the systems or components receive protection from the implemented controls (or portion of security controls) that are developed, implemented, assessed, authorized, and monitored by entities other than those responsible for the systems or components (i.e. entities internal or external to the organizations where the systems or components reside). Common controls are usually deemed inheritable. The concept of common controls is introduced later.

Maintaining a defense-in-depth capability is a major reason for not inheriting a control. Many common controls that are normally deemed as inheritable should not be inherited, because they are required at multiple points within a multi-layer defensive architecture. For example, Defense in Depth Functional Implementation Architecture (DFIA), Cybersecurity Safety (CYBERSAFE), and Insider Threat programs severely limit control inheritability.

Any control that depends on having access to network traffic datagram content is not inheritable if the datagram is encrypted.

A technical control is inheritable only if the mechanism used is successfully evaluated under a National Information Assurance Partnership (NIAP) program protection profile.

A Communications Security (COMSEC), Data-at-Rest protection, or other cryptographic-mechanism based control is inheritable only if the cryptographic module or system is NSA-certified or validated under the NIST Cryptographic Module Validation Program (CMVP).

#### 4.2 Inherited

Inherited security controls are security controls fulfilled by systems or entities external to the system's assessment boundary. An inherited control is a security control which affords an IS protection and compliance status. Inherited security controls can be divided into two categories: security controls inherited from another authorized system, and common controls. Inherited controls are usually common controls and are provided by a Common Controls Provider (CCP). The concept of common controls and CCP are introduced in Section 4.3.5.

#### 4.3 NIST SP 800-53

The NIST SP 800-53 (current version), *Security and Privacy Controls for Federal Information Systems and Organizations*, provides:

- A catalog of security and privacy controls for federal ISs and organizations, and
- A process for selecting controls to protect organizational operations (including mission, functions, image, and reputation), organizational assets, individuals, other organizations, and the Nation from a diverse set of threats including hostile cyber-attacks, natural disasters, structural failures, and human errors.

Security controls detailed within SP 800-53 are the foundation for the inheritance process. It is those security controls which, under select conditions and mutual concurrence between issuing and receiving parties, are deemed inheritable and/or inherited.

#### **4.3.1 CNSSI 1253 Security Categorization and Control Selection for National Security Systems**

CNSSI 1253, together with NIST SP 800-53, addresses information security compliance requirements of National Security Systems (NSS), providing a common foundation for information security across the U.S. Federal Government. Although the CNSSI 1253 states that it is applicable to NSSs, the DoD has adopted the NSS baseline control assignments for all DoD ISs. This Instruction also provides NSS-specific information on developing and applying overlays for the national security community and parameter values for NIST SP 800-53 security controls that are applicable to all NSS. The CNSSI 1253 identifies which of the SP 800-53 security controls are applicable to NSS and, as such, those controls that may be included in the inheritance process.

#### **4.3.2 Security Controls**

Per the CNSSI 4009, security controls are “The management, operational, and technical controls (i.e., safeguards or countermeasures) prescribed for an IS or an organization designed to protect the confidentiality, integrity, and availability of its information.”

According to the NIST SP 800-53, there are three distinct types of security controls designations that define the scope of the applicability for the control, the shared nature of the control, and the responsibility for control development, implementation, assessment, and authorization. These designations include:

- System-specific controls (see paragraph 4.3.3)
- Common controls (see paragraph 4.3.4)
- Hybrid controls (see paragraph 4.3.5)

Security controls not designated as common controls are considered system-specific or hybrid controls. The various types of controls are defined in Sections 4.3.3-4.3.5.

Partitioning security controls into common, hybrid, and system-specific controls can result in significant implementation and assessment cost savings to organizations, as well as a more consistent application of security controls organization-wide. While security control partitioning into common, hybrid, and system-specific controls is conceptually straightforward and intuitive, the application takes a significant amount of planning and coordination. At the IS level, determination of common, hybrid, or system-specific security controls follows the development of a tailored baseline. It is necessary to first determine what security capability is needed before organizations assign responsibility for how security controls are implemented, operated, and maintained.

The determination as to whether a security control is a common, hybrid, or system-specific is context-based. Security controls cannot be determined to be common, hybrid, or system-specific simply based on reviewing the language of the control. For example, a control may be system-specific for a particular IS; at the same time, that control could be a common control for another system if is provided as inheritable, which would inherit the control from the parent system. One indicator of whether a system-specific control may also be a common control for other ISs is to consider who or what depends on the functionality of that particular control. If a certain part of an IS or solution external to the system boundary depends on the control, then that control may be a candidate for common control identification.

### 4.3.3 Control Correlation Identifier (CCI)

The Control Correlation Identifier (CCI) provides a standard identifier and description for each of the singular, actionable statements that comprise a security control or cybersecurity best practice. CCIs bridge the gap between high-level policy expressions and low-level technical implementations. CCI allows a security requirement that is expressed in a high-level policy framework to be decomposed and explicitly associated with the low-level security setting(s) that must be assessed to determine compliance with the objectives of that specific security control. This ability to trace security requirements from their origin (e.g., regulations, cybersecurity frameworks) to their low-level implementation allows organizations to readily demonstrate compliance to multiple cybersecurity compliance frameworks. CCI also provides a means to objectively rollup and compare related compliance assessment results across disparate technologies.

Since most security controls are made up of multiple CCIs, the inheritance process is broken down to the CCI level. Each CCI has been identified as inheritable, potentially inheritable, or not inheritable. Not all CCIs are inheritable, meaning most security controls are not inheritable in their entirety. It is a rare few security controls that are inheritable in their entirety with all CCIs as inheritable.

**Operational CCIs:** These CCIs are primarily provided by Fleet/Site entities, organizations, locations.

**Technical CCIs:** These CCIs are primarily provided by Critical Inheritance Providers. Current CIPs (defined in Section 5.1.5) include CANES, CND, ISNS, STACC, SubLAN, Data Centers, NMCI, and ONE-Net.

**Note:** Responsibility for compliance to a CCI may not be shared/divided between multiple entities. CCIs must be fulfilled by either the system or its CCP.

### 4.3.4 System-Specific Security Controls

CNSSI 4009 defines “a System-Specific Security Control as a security control for an IS that has not been designated as a common security control or the portion of a hybrid control that is to be implemented within an IS.” System-specific controls and associated CCIs not inheritable, and are the primary responsibility of IS owners and their respective authorizing officials.

### 4.3.5 Common Security Controls

CNSSI 4009 defines a Common Security Control as “a security control that is inherited by one or more organization ISs”. NIST SP 800-53 identifies common controls as “security controls whose implementation results in a security capability that is inheritable by one or more organizational ISs.”

Common Security Controls:

- Support multiple ISs efficiently and effectively as a common capability.
- Promote more cost-effective and consistent security across the organization and can also simplify risk management activities.
- Significantly reduces the number of discrete security controls that have to be documented and tested at the IS level which in turn eliminates redundancy, gains resource efficiencies, and promotes reciprocity.

Security capabilities provided by common controls can be inherited from many sources including, for example, organizations, organizational mission/business lines, sites, enclaves, environments of operation, or other ISs. Many of the controls needed to protect organizational ISs (e.g., security awareness training, incident response plans, physical access to facilities, rules of behavior) are excellent candidates for common control status. In addition, there can also be a variety of technology-based common controls (e.g., Public Key Infrastructure [PKI], authorized secure standard configurations for clients/servers, access control systems, boundary protection, cross-domain solutions). By centrally managing and documenting the development, implementation, assessment, authorization, and monitoring of common controls, security costs can be amortized across multiple ISs.

According to the DOD 8510.01, common controls are selected as “common” and provided via the RMF Knowledge Service (KS), based on risk assessments conducted by these entities at the Tier 1 and Tier 2 levels. By identifying the security controls that are provided by the organization as common solutions for systems, and documenting the assessment and authorization of the controls in a security plan, individual systems within those organizations can leverage these common controls through inheritance.

When common controls are used to support a set of systems, those common controls must be well-defined and included in a formal methodology and rule-set for consistent implementation and management. In addition to simplifying risk management activities, common controls are also a cost-effective way to promote consistent security information. When the organization allocates security controls to specific entities in the organization it is simultaneously assigning responsibility and accountability for system specific-, hybrid-, and common controls.

Tier 2: The DON Chief Information Officer (CIO) identifies DON-specific common security controls that are satisfied by existing DON policy and guidance and are applicable throughout the DON. Tier 2 common security controls may be more stringent than Tier 1 common security controls but may not negate or contradict Tier 1 common security controls. Additionally, Tier 2 common security controls may not prevent interoperability or reciprocity between or among the DoD Components. DON ISs and PIT systems are automatically compliant with Tier 2 common security controls because they implement and are satisfied by existing documented DON policies and guidance. Risk associated with Tier 2 common security controls is assumed by the DON. The Authorizing Official (AO) for the Tier 2 common security controls is the DON Senior Information Security Officer (SISO). Tier 2 common security controls are identified by DON and should be posted to the DON's KS workspace and in the Navy Enterprise Security Control and CCI Inheritance Catalog.

#### **4.3.6 Hybrid Security Controls**

CNSSI 4009 and the RMF Knowledge Service defines a Hybrid Security Control as a “security control that is implemented in an IS in part as a common control and in part as a system-specific control.” These are sometimes referred to as “shared controls”.

**Note:** Hybrid security controls are sometimes referred to as “shared” controls. That term is not valid and must not be used, as it causes confusion.

**Note:** Hybrid controls should not be confused with the Conditions and Constraints (C&C) required for inheriting any other inheritable control.

Hybrid status is assigned to security controls when one part of the control is common and another part of the control is system-specific. The CCP assumes responsibility for the common portion of the control and the AO authorizing the IS assumes responsibility for the system-specific portion of the control. Within hybrid controls, there will be CCIs that are provided/satisfied by the CCP and CCIs that must be satisfied by the inheriting system.

Hybrid Examples:

1. Organizations may choose to implement the Contingency Planning security control (CP-2) as a predefined template for a generalized contingency plan for all organizational ISs with Information System Owners (ISO) tailoring the plan, where appropriate, for system-specific uses.
2. The security control AU-2 (Audit Events) may be a hybrid security control with responsibilities for the CCPs and system owners. The security control states:
  - Determines that the information system is capable of auditing the provider-defined required events;
  - Coordinates the security audit function with other provider entities requiring audit-related information to enhance mutual support and to help guide the selection of auditable events;
  - Provides a rationale for why the auditable events are deemed to be adequate to support after-the-fact investigations of security incidents; and
  - Determines the defined audited events to be audited within the information system, along with the frequency of (or situation requiring) auditing for each identified event.
3. Responsibilities for satisfying a hybrid control might be divided as follows:

Provider Responsibilities:

- Identify the auditable events that must be captured in the systems.
- Define the subset of auditable events that the systems must be capable of auditing.
- Define the frequency of auditing for each identified event.

System Owner Responsibilities:

- Identify auditable events that should be captured in the system.
- Ensure that audit functions are coordinated with other entities to enhance mutual support and to help guide the selection of auditable events.
- Ensure system-specific auditable events are captured.
- Ensure system is capable of auditing the subset of auditable events that the provider system is capable of auditing

For hybrid security controls, assessment test results and supporting documentation for the common portion of the hybrid control are maintained by the providing organization or system and are made available to Security Controls Assessors (SCA) of inheriting systems on request.

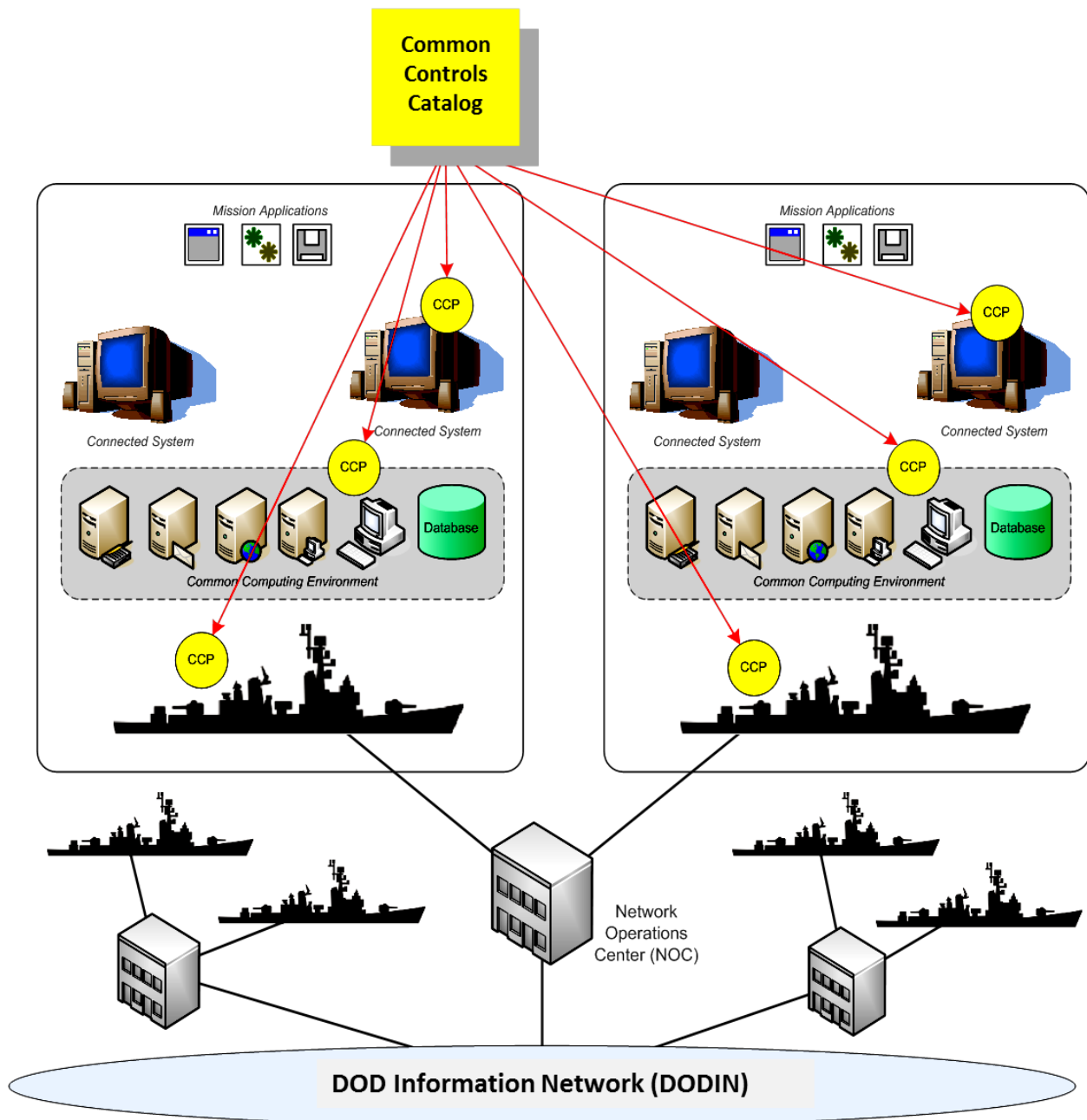
The security plan of the inheriting organization or system must identify the common portion of hybrid security controls inherited from external providers, and establish minimum assurance requirements for those security controls. The security authorization package must also contain, or provide links to, the appropriate documentation for all security controls that are being satisfied through inheritance (e.g., security authorization packages, contract documents, Memoranda of Agreement (MOA), and Service Level Agreements (SLA)).

## 5.0 Navy Enterprise Inheritance Governance

Previous policies on enterprise inheritance have been written at the conceptual level. A governance strategy is developed at the procedural level to successfully implement and manage enterprise inheritance.

Understanding the process and identifying applicable requirements and affected stakeholders is the first step in developing governance procedures. RMF requires identification of enterprise architecture components supporting and benefiting from the implementation of enterprise inheritance within the RMF construct. Relationships between security providers and recipients must be documented to identify interdependencies, and to specify the impact levels at which security controls will need to be provided.

An enterprise inheritance Common Operational Picture (COP) is necessary for risk managers to identify relationships, specify impact levels, and designate common security controls that are standardized across the enterprise. A COP enables the organization to scope other capabilities that may be provided regionally at an appropriate impact level. Figure 2 depicts the concept of the CCP as an important element of the proposed NEIM. The CCP is an organization official responsible for the development, implementation, assessment and monitoring of common controls (i.e., security controls inheritable by ISs). The CCP concept is fully defined in Section 5.3.



**Figure 2. Enterprise Inheritance Common Operational Picture (COP)**

## 5.1 Roles and Responsibilities

### 5.1.1 DoD CIO and DON CIO

Per the RMF KS *Identifying Common Security Controls*, Common security control identification is the responsibility of the DoD CIO, DON CIO, and other organizations and entities that provide solutions for common controls.

It is the responsibility of the DoD CIO, DON CIO, and Navy organizations and entities that provide solutions for common security controls to:

- Identify the security controls, including the common portions (CCIs) of hybrid security controls, that are provided as common solutions for IS and PIT systems.
- Designate inheritable security controls in eMASS in order for an inheriting system to use them.
- Document the assessment and authorization of common security controls, including the common portions (CCIs) of hybrid security controls, in a SP (or equivalent document), and make that documentation available to individual systems inheriting the common security controls.

### **5.1.2 Navy Authorizing Official (NAO)**

Per the SECNAV Instruction 5239.3C, the Navy AO (NAO) has the authority to formally assume responsibility for allowing an IS to operate at an acceptable level of risk to organizational operations and assets, individuals, other organizations, and the Nation. The NAO is assigned responsibility for assessing, evaluating, mitigating, accepting, and monitoring risk. The implementation of enterprise inheritance is managed through the NAO function with the RMF supporting enterprise inheritance dependencies and accountability.

The NEIM establishes procedures to standardize the implementation, assessment, management and reporting of inheritance across an area of responsibility under the NAO. Under the NEIM, the NAO is responsible for accepting the risk resulting from the deployment of the security controls provided by CCPs and inherited by organizational ISs.

### **5.1.3 Security Controls Assessor (SCA)**

The SCA's role in inheritance is to work with the enterprise systems, sites and system owners in the categorization and selection of security controls processes. Then, the SCA reviews and validates the security plans and the selection of security controls based on the site/system categorization. This review and validation includes inheritable and inherited controls. To determine the overall effectiveness of the security controls, the SCA conducts an independent, comprehensive assessment of the management, operational, and technical controls employed within or inherited by a Navy system.

### **5.1.4 Common Controls Provider (CCP)**

Per the NIST SP 800-37, the CCP is an individual, group, or organization responsible for the development, implementation, assessment, and monitoring of common controls (i.e., security controls inherited by ISs). This is sometimes referred to as the "parent" system that provides common controls to the "child" systems that are connected.

The CCP has a role in managing inheritable controls. The role of the CCP can be defined at the enterprise level. According to the Navy RMF Process Guide (RPG), it is the primary responsibility of the CCPs to ensure security capabilities provided by the common controls can be used by inheriting systems with a degree of assurance appropriate for their information protection needs.

Additionally, the concept of security controls inheritance mandates that inheritors meet conditions identified for each security control. Many controls require specific conditions to be met before inheritance can be implemented. These are known as Conditions and Constraints (C&C). When common security controls are provided, applicable conditions must be identified and verified to the satisfaction of the CCP before capability can be distributed.

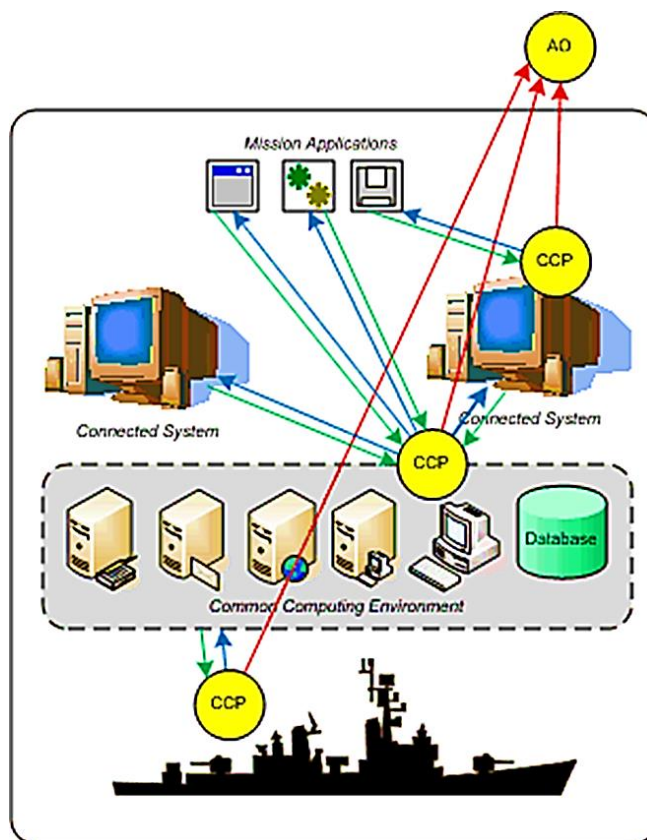
Common controls must be assessed at the highest impact level of the recipient. This requires careful planning at the enterprise level to develop an enterprise inheritance framework that recognizes valid opportunities for inheritance. While many systems will require a high-level model to support inheritance activities, it is important to assess the individual needs of each system to provide adequate inheritability.

CCPs may also be an ISO when the common controls are resident within an IS. The organization consults ISO when identifying common controls to ensure that the security capability provided by the inherited controls is sufficient to deliver adequate protection.

Per the NIST SP 800-37, CCPs are responsible for:

- Documenting common controls in a security plan (or equivalent document prescribed by the organization)
- Ensuring that common controls are developed, implemented, and assessed for effectiveness by qualified assessors with a level of independence required by the organization
- Documenting assessment findings in a security assessment report
- Producing a plan of action and milestones for all common controls deemed less than effective (i.e., having unacceptable weaknesses or deficiencies in the controls)
- Receiving authorization for the common controls from the designated authorizing official (NAO) monitoring common control effectiveness on an ongoing basis.

Figure 3 depicts the relationship of the AO to the CCP.



**Figure 3. AO Relationship to the CCP**

Table 2 defines each governance tier and the common control sources for inheritance.

| Governance                       |                      | Common Control Source                                                                                                  |
|----------------------------------|----------------------|------------------------------------------------------------------------------------------------------------------------|
| Tier 1: Organization             | DoD Level            | DoD CIO, ISRMC, DSAWG, DoD SISO, DoD Cybersecurity Architecture, RMF TAG, Knowledge Service                            |
| Tier 2: Mission/Business Process | DoD Component Level  | PAO, DON SISO (DON CIO)                                                                                                |
| Tier 3: IS/PIT Systems           | Program/System Level | Navy AO (FFC/C10F) , IS or Platform IT (PIT) System Cybersecurity Program, Enclave Owners, Echelon II POC or III, etc. |

**Table 2. Common Control Sources**

### 5.1.5 Critical Inheritance Provider (CIP)

For the Navy, the Critical Inheritance Provider (CIP) is a CCP whose volume of inheritable security controls makes it capable of providing an “inheritance backbone” to the many subsystems that will connect to it within an enterprise environment. Navy enterprise hosting level backbone architectures, enclaves and network environment systems are all likely candidates for identification as a CIP.

The criteria to be designated a CIP is:

- Echelon II endorsement of inheritance strategy
- Current authorization
- IS that is a provider of primary security services
- RMF package that defines CIP approved by Echelon II (Triggered up to step 7 in eMASS for review)

CIP examples include:

- Hosting facilities (Navy and DoD Data Centers)
- Enterprise Services/Networks (Navy Marine Corps Intranet (NMCI), Consolidated Afloat Networks and Enterprise Services (CANES), OCONUS Navy Enterprise Network (ONENET))
- Sites/Circuits (Automated Digital Network Services (ADNS))
- Computer Network Defense (CND) Suites

CIPs have the role of managing their inheritable controls to ensure satisfaction and compliance of that control. They are responsible for the development and implementation of the solution that satisfies the inheritable control(s). This includes the assessment, monitoring, and documentation of the common controls they provide.

CIPs identify inheritable security controls that are made available to systems that are nested within the environment/enclave through agreements between the CIP and the nested systems. Risks introduced via inheritable security controls at the environment/enclave level must be documented and either accepted, mitigated, or rejected by the AO.

### 5.1.6 Information System Owner (ISO)

The ISO or Program Manager (PM) has an important role in inheritance. In addition to their other RMF responsibilities, the ISO coordinates with the CCP/CIP from which they plan to obtain their inheritable controls. This important step ensures that the CCP/CIP knows of the inheriting entity's requirements, and works to ensure compliance with the C&Cs for each control.

## 6.0 Identifying and Designating Common Security Controls

Since common security controls are those controls which may be inherited by one or more organizational ISs, if an IS inherits a common control, the inheriting system does not need to explicitly implement that control on its own—that is, the security capability is being provided by another entity.

Common controls are selected as “common” and provided based on risk assessments conducted by these entities at the Tier 1 and Tier 2 levels. By identifying those security controls provided by the organization as common solutions for IS and PIT systems, and documenting the assessment and authorization of the controls in a Security Plan, individual systems within those organizations can leverage these common controls through inheritance. The KS identifies common controls for DoD and provides additional information on how they are documented within the security authorization package.

Organizational decisions on which security controls are designated as common controls may greatly affect the responsibilities of individual ISOs, with regard to the implementation of controls in a particular baseline. Common control selection can also affect the overall resource expenditures by organizations (i.e., the greater the number of common controls implemented, the greater potential cost savings).

Common Security Controls are identified at the Tier 1, 2, and 3 levels as depicted in Figure 1 in Section 3.0 above.

**Note:** Tier 1 and 2 common controls and CCIs may not yet be published on the RMF KS and/or Navy Certification and Accreditation (C&A)/A&A portal at the time of this guide publication. It is the responsibility of the PM/ISO, ISSE, and ISSM to periodically visit these portals for new information. The Navy implementation of common controls will evolve to include a mechanism for communication of changes as well as the availability of common control authorization results and continuous monitoring information to those organizational entities inheriting common controls.

### 6.1 Common Controls Procedures

It is the responsibility of the DoD CIO, DON CIO, and Navy/Marine /Corps organizations and entities that provide solutions for common security controls to:

- Identify the security controls, including the common portions of hybrid security controls, that are provided as common solutions for IS and PIT systems.
- Designate inheritable security controls in eMASS in order for an inheriting system to use them.
- Document the assessment and authorization of common security controls, including the common portions of hybrid security controls, in a Security Plan (or equivalent

document), and make that documentation available to individual systems inheriting the common security controls.

- Tier 1:
  - DoD CIO identifies common security controls that are satisfied by existing DoD policy and guidance
  - DoD common security controls are applicable throughout the DoD
  - DoD ISs and PIT systems are automatically compliant with Tier 1 common security controls because they implement and are satisfied by existing documented DoD level policies
  - Risk associated with Tier 1 common security controls is assumed by the DON through their concurrence with the DoD level policies as issued
  - The AO for the Tier 1 common security controls is the SISO
  - Navy systems are automatically compliant with Tier 1 common security controls because they implement and are satisfied by existing documented DoD level policies
  - The DoD RMF Knowledge Service provides a list of the DoD Enterprise (Tier 1) common security controls that are satisfied by existing policy and guidance and applicable throughout the DoD. The Navy Enterprise Inheritance Control Correlation Identifier (CCI) Selector Catalog (to be published on the Navy RMF Knowledge Management (KM) Portal when finalized)
- Tier 2:
  - DON CIO identifies DON-specific common security controls that are satisfied by existing DON policy and guidance
  - DON-specific common security controls are applicable throughout the DON
  - Tier 2 common security controls may be more stringent than Tier 1 common security controls, but will not negate or contradict Tier 1 common security controls
  - Tier 2 common security controls will not prevent interoperability or reciprocity between or among the DoD Components
  - DON ISs and PIT systems are automatically compliant with Tier 2 common security controls because they implement and are satisfied by existing documented DON policies and guidance
  - Risk associated with Tier 2 common security controls is assumed by the DON organization providing the security control
  - The AO for the DON Tier 2 common security controls is the DON SISO
  - Tier 2 common security controls are identified by DON CIO and is posted to the DON KS workspace found in the Navy Enterprise Inheritance Control Correlation Identifier (CCI) Selector Catalog to be published on the Navy RMF KM Portal when finalized
- Tier 3:
  - Enclaves on the Department of Defense information network (DoDIN – JP1.02) with a current ATO are designated as Tier 3 common control providers.
  - Navy environments/enclaves may identify enterprise-specific common security controls that are made available to systems (other enclaves, major applications, PIT systems) hosted within the environment/enclave through agreements between the environment/enclave and the hosted systems. This includes infrastructure type security controls such as physical, environmental, and some policies (i.e. physical access policies) provided by the site(s) hosting the enclave, when such controls are

documented in the hosting enclave's security authorization package. It may also include security controls provided to the hosting enclave from a remote entity (e.g., MA-4, Non-local Maintenance), where applicable.

- There are instances when enclaves do not offer all Tier 3 physical or environmental security controls required by hosted systems as common security controls (e.g., a requirement for enhanced physical security, such as a separate secured room to house system hardware). In these instances the hosted system negotiates an agreement with the site for provision of the capabilities or services required to satisfy any additional security controls or provides the capability or service itself.
- Risks introduced via common security controls at the environment/enclave level must be documented and either accepted, mitigated or rejected by the NAO
- Common Controls may be provided by a Tier 3 organization to be inherited from another tier 3 organization (example: data centers offer common controls for systems being hosted/ nested within the enclave)
- Current lists of enterprise environment/enclave-level common security controls are maintained locally by the hosting enclaves and found in the Navy Enterprise Inheritance Control Correlation Identifier (CCI) Selector Catalog to be published on the Navy RMF KM Portal when finalized.
- Obtain the current list of Tier 3-specific common security controls from the appropriate CCP
- Document these common controls as inherited controls in the inheriting system's Security Plan (SP) and annotate as such in eMASS
- Where framework incompatibilities exist between DIACAP and RMF-authorized systems, inheritance may not be electronically-established via eMASS. Under such circumstances, a memorandum of understanding (MOU), MOA, SLA, or other written inheritance agreement must be provided as an external artifact to identify and demonstrate concurrence between issuing and receiving parties for all inherited controls.
- Systems may receive common controls from multiple Tier 3 providers (CCPs) within different echelons of the Navy, and due diligence must be performed to consider these multiple echelons and hosting environments when developing a system's security control list.
- The DoD RMF KS provides a reference link to the current Tier 3 DISA Facility Controls and DISA Network Controls, with a recommendation that enclaves and systems residing in enclaves refer to this list as a starting point in establishing their security control inheritance relationships and compliance with the RMF. The artifacts are essentially spreadsheets that show controls that are specific to DISA facilities and networks, and could be made inheritable or shared.
- A site is a physical entity with a defined boundary (e.g., a building, post, ship) that provides capabilities or services required to satisfy infrastructure type security controls (e.g., physical and environmental) to hosted systems.
- Security controls available for inheritance (e.g. common security controls) by IS and PIT systems must be identified and have associated compliance status provided by the hosting or connected systems. Evidence must be included or referenced in the IS

security plan to show the IS actually receives protection from the inherited security controls.

- A security control enhancement may only be inherited when the base security control is included in the baseline security control set. The base security control (e.g., AC-2, Account Management) needs to be within the baseline security control set or inherited with the enhancement (e.g., AC-2 (1), Account Management/ Automated System Account Management).
- Except for hybrid security controls, a system may not inherit a portion of a security control. The security control must be inherited in its entirety.
- Controls related to IT services provided by external (i.e., non-DoD) service providers are not inherited. However, the system PM or ISO is responsible for ensuring the adequacy of the security proposed by potential service providers and the security approach, including implemented security controls, is documented in a service level agreement (SLA), contract, or order included in the system's security authorization package. For external IT services provided by non-DoD federal government agencies, interagency agreements or government statements of work must contain requirements for SLAs that include the implementation of appropriate security controls. IT services purchased from commercial organizations must include required security controls in requests for proposals, assess the adequacy of security proposed by potential service providers, and document the accepted security approach in the resulting contract or order. Per the DoD RMF KS, an exception to the foregoing is DoD organizations contracting for external IT services in the form of commercial cloud computing services must comply with DoD cloud computing policy and procedural guidance as published at [http://iase.disa.mil/cloud\\_security/Pages/index.aspx](http://iase.disa.mil/cloud_security/Pages/index.aspx).
- Common security controls that are non-compliant (NC) can be provided and inherited. The inheriting system's AO must make a decision to accept the risk of inheriting the NC security control to their system. Typically, Tier 1 and Tier 2 common security controls that are NC are inherited without change because the organization providing the common security control has assumed the risk associated with the NC security control, thus relieving the IS or PIT system AO of assuming residual risk for that common security control.
- If a system inherits a common security control that has an assessment frequency/periodicity setting that is more frequent than the receiving system requires, the receiving system has to comply with the frequency setting of the inherited security control. For example, if the common security control provider assesses the security control quarterly the receiving IS must also assesses the security control quarterly even though the SCA and AO of the receiving system determine that an annual assessment of the security control is sufficient. Conversely, a receiving system may increase the frequency of assessment required for an inherited common security control if the AO of the receiving system determines that more frequent assessment is warranted.
- For inherited security controls, assessment test results and supporting documentation are maintained by the providing organization or system and are made available to SCAs of inheriting systems on request. SCAs should maximize the reuse of existing assessment (i.e., a leveraged authorization), and T&E documentation in their assessment of the system.

- The Security Plan must identify all security controls inherited from external providers, and establish minimum assurance requirements for those security controls. If a security control(s) is inherited from an enclave outside of DoD, it must be documented in an MOA, an MOU or another type of formal agreement.
- The security authorization package must contain, or provide links to, the appropriate documentation for all security controls that are being satisfied through inheritance (e.g., security authorization packages, contract documents, MOAs, and SLAs).

Security controls not designated as common security controls are considered system-specific or hybrid security controls. System-specific security controls are the primary responsibility of IS owners and their respective authorizing officials. As defined in paragraph 4.3.5 above, organizations assign a hybrid status to security controls when one part of the security control is common and another part of the security control is system-specific.

## **6.2 Conditions and Constraints**

Conditions and Constraints (C&Cs) define specific requirements and restrictions, established by the inheritance provider, that inheriting systems must comply with to inherit a security control. C&Cs may be physical (e.g., power usage), logical (e.g., data traffic restrictions), or administrative (e.g., centralized management); they must consider the requirements and capabilities of both the inheritance provider as well as the inheritor. C&Cs must be met to demonstrate the successful compliance with the requirements of the control.

Note: C&Cs are not Hybrid Controls. Hybrid controls have specific portions of the control implemented by the provider and inheritor.

C&Cs are usually defined by the provider as part of an inheritable control. The provider shall identify the conditions under which the security control Control Correlation Identifier (CCI) may be inherited, the constraints the inheriting system must assume to inherit that CCI, and the criteria by which compliance to this CCI will be evaluated. The inheriting system must meet/satisfy the C&Cs by demonstrating compliance with the established criteria. This means the validation procedures defined by the provider must be followed, and their compliance documented to show the inherited control as satisfied. In some cases, C&Cs may specify the requirements of a hybrid control and define the relationship that must be established between the provider and inheritor.

When validating the security controls during RMF Step 4 Assess Security Controls, the Validator ensures that all C&Cs of the inheritable security control are met by the inheriting system for proper inheritance of that control.

## **6.3 Security Plans**

A Security Plan (SP) is a formal document in the A&A package found in eMASS. The SP provides an overview of the security requirements for an IS and describes the security controls in place or planned for meeting those requirements. Security Plans for individual ISs identify which security controls required for those systems have been designated by organizations as common controls and which controls have been designated as system-specific or hybrid controls. ISOs are responsible for any system-specific implementation details associated with common controls. These implementation details are identified and described in the security plans for the individual ISs. Lead ISSOs for organizations coordinate with CCPs (e.g., facility/site managers, human resources managers, intrusion detection system owners) to ensure that the required controls are

developed, implemented, and assessed for effectiveness. Collectively, the SPs for individual ISs and the organization-wide information security program plans provide complete coverage for all security controls employed within organizations.

The SP must identify all common controls inherited from external providers, and establish minimum assurance requirements for those controls.

## 7.0 Inheritance and the Risk Management Framework (RMF)

Common Controls and Inheritance in RMF enables deployment of enterprise-wide cybersecurity solutions (i.e. build once, use many times) via inheritance of centrally built, hosted, and authorized capabilities. Inheritance dramatically cuts down the number of controls that need to be validated for a major application going into a hosted environment saving time and resources.

Common Security Controls are inherited by one or more organizational information systems are identified and made available to be inherited by each RMF Governance Tier

- Tier 1: DoD CIO identifies common security controls that are satisfied by existing DoD policy and guidance, and are applicable throughout the DoD. These are published within the RMF KS and eMASS.
- Tier 2: Component CIO (DON CIO) identifies Component-specific common controls that are satisfied by existing Component policy and guidance and are applicable throughout the Component. These are published within eMASS
- Tier 3: Enclaves may identify common security controls enclave-specific (including network and physical controls) that are made available to ISs that are nested within the enclave through agreements between the enclave and the nested ISs. These are published with the Navy Enterprise Security Controls and CCI Inheritance Catalog.

Table 3 shows the RMF steps as they relate to the Inheritance Process. The table lists the high level requirements to be performed by Inheritance Providers and Inheriting Systems in the RMF Steps.

|                             | Inheritance Providers                                                                                                                     | Inheriting Systems                                                                                   |
|-----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------|
| <b>Step 1</b><br>Categorize |                                                                                                                                           |                                                                                                      |
| <b>Step 2</b><br>Select     |                                                                                                                                           | During the Controls Selection process, Controls/CCIs to be inherited must be identified and approved |
| <b>Step 3</b><br>Implement  | Inheritable Controls/CCIs must be identified and approved, Conditions/Constraints must be established, and validation procedures defined  | Conditions/Constraints for inheritability must be met                                                |
| <b>Step 4</b><br>Assess     | The state (compliant/non-compliant) of Inheritable controls, their Conditions/Constraints, and implementation processes must be validated | Inherited Controls/CCIs must be validated against the provider's validation procedures               |
| <b>Step 5</b><br>Authorize  | Inheritable controls will be authorized by the AO                                                                                         | Inherited controls will be authorized by the AO                                                      |
| <b>Step 6</b><br>Monitor    | Inheritance providers must assess inheritable controls annually and keep inheriting systems informed of any status change                 | Inheriting systems must perform continuous monitoring to ensure inherited controls remain valid      |

**Table 3: Inheritance-specific PMO activities to be completed during RMF**

## 7.1 RMF Step 1 - System Categorization

Inheritance plays a minor role in Step 1 of the RMF process. However, there are some procedures in Step 1 that have an influence on the Inheritance process. Those procedures that will influence inheritance include:

- Determine potential impact values for the information type(s) processed, stored or transmitted or protected by the information system; and for the information system.
- Identify overlays that apply to the information system and its operating environment to account for additional factors (beyond impact) that influence the selection of security controls.

CYBERSAFE - Every IS and PIT system will be assessed according to the Information Assurance Technical Authority (IATA) CYBERSAFE Grade Criteria Standard and will be assigned a CYBERSAFE Grade. Systems assigned a CYBERSAFE grade of A (Mission Critical) or B (Mission Essential) are designated as CYBERSAFE critical items, and CYBERSAFE will add additional security controls and enhanced assurance control requirements in a similar manner as a Security Control Overlay. Systems assigned a CYBERSAFE grade of C will have no additional controls added. For inheritance, these additional controls may impact the IS's security controls selection.

## 7.2 RMF Step 2 - Security Controls Selection

Step 2 – Security Control Selection is a multi-step process consisting of (1) selecting the initial baseline of security controls, (2) selecting security control overlays where appropriate, (3) tailoring the initial security control baseline, and (4) identifying inherited and/or hybrid security controls.

Step 2 of the RMF process includes some major inheritance procedures.

- Select the initial security control set
- Choose the appropriate set of baseline controls in CNSSI No 1253, based on the security category of the information system (i.e., the impact value determined for each security objective)
- Apply any overlays identified as applicable during security categorization
- Tailor the initial security control set
- Identify and designate common controls, apply scoping considerations, select compensating controls, assign specific parameter values, and supplement the baselines based on a risk assessment
- Determine whether or not additional assurance-related controls are needed to increase the level of trustworthiness in the information system and supplement as needed

### 7.2.1 Security Control Baseline

All DoD systems use NIST 800-53 and CNSSI 1253 to establish a security control baseline. The baseline will be dependent on the System Categorization established in RMF Step 1.

Per the RMF KS, based on the system categorization established in Step 1 of the RMF, Step 2 explains the process for establishing a security control baseline and selecting a final security control set for DoD IS and PIT systems, as found in CNSSI 1253 with further discussion and detail in Enclosure 6 of DoDI 8510.01.

- For a complete description of the controls selection process is available in the RPG. From an inheritance perspective, the following elements are relevant: Identify Inherited Common / Hybrid Security Controls: Common and hybrid security controls are identified and approved during the Control Selection process.
- Document the Final Security Control Set: Document the resulting set of security controls, along with the supporting rationale for selection decisions and any system use restrictions, in the security plan. The security plan must identify all common controls inherited from external providers, and establish minimum assurance requirements for those controls.

For inheritance, the specific relevant step in the tailoring process is identifying and designating common controls in initial security control baselines. Every security control from the applicable security control baseline is accounted for either by the organization (e.g., CCP) or by the ISO. The security control selection process also applies to CCPs and the authorizing officials rendering authorization decisions for common controls deployed within organizations. The security controls baselines are documented in the security plan.

## **7.2.2 Hybrid Controls**

As discussed in paragraph 4.3.5, a Hybrid Security Control is a security control that is implemented in part as a common control and in part as a system-specific control. The CCP assumes responsibility for the common portion of the control and the inheriting IS assumes responsibility for the system-specific portion of the control.

Hybrid controls usually exist when a CCP cannot completely provide/fulfill an inheritable security control. In this case, in order to meet the requirements of a security control, the CCP indicates what can be provided as inheritable through CCIs and C&Cs. For hybrid security controls, assessment test results and supporting documentation for the common portion of the hybrid control are maintained by the providing organization or system and are made available to SCAs of inheriting systems on request.

When a control's CCIs are satisfied from different sources (e.g., half are system-specific and half are inherited), the control is said to be a hybrid control. Testing for the CCIs that are satisfied by the inherited source is documented in the source's eMASS record. Systems that have approved inheritance from that source in eMASS will be able to see the testing results.

For a hybrid control, the Security Plan of the inheriting program or system must identify the common portion of hybrid security controls inherited from CCP, and establish minimum assurance requirements for those security controls. The security authorization package must also contain, or provide links to, the appropriate documentation for all security controls that are being satisfied through a hybrid control inheritance situation (e.g., security authorization packages, contract documents, MOU/MOA, and SLAs).

## **7.2.3 eMASS Authorization Packages**

The eMASS authorization packages for any CCP/CIP and IS are the main records where inheritance is documented, assessed, and enforced. The goal of this documentation is a direct traceability of compliance of all inheritable/inherited controls from the provider to the inheriting system.

For CCP/CIPs, all inheritable controls must be marked as inheritable in the associated eMASS authorization package. The compliance of that control must be shown with the C&Cs and requirements for inheritance. Additionally, the evaluation criteria must be clearly documented for each control.

For inheriting ISs, all inherited controls must be clearly marked as inherited in the IS's eMASS authorization package. The CCP/CIP must be clearly shown for traceability. It must show how the C&Cs and requirements are met by the inheriting IS.

A manual process for traceability of CCIs must be used until eMASS is updated to track inheritance at the CCI level.

#### **7.2.4 Navy Enterprise Security Control and CCI Inheritance Catalog**

The Navy IATA (SPAWAR 58000) has published the Navy Enterprise Security Control and CCI Inheritance Catalog; this catalog lists a wide range of possible inheritable security controls / CCIs and the source of that inheritance. Including, the Tier 1 (DoD) and Tier 2 (DON) inheritable Security Controls and CCIs. It also provides, where available, the authoritative source documentation to validate that inheritance. It assists with identification of potentially inheritable Tier 3 controls and CCIs, and those controls/CCIs that may not be inherited. This catalog will be updated as Controls, CCIs, and amplifying information becomes available. The Navy Enterprise Security Controls and CCI Inheritance Catalog can be found at **TBD**

#### **7.2.5 Inheriting Security Control / CCI Non-compliance**

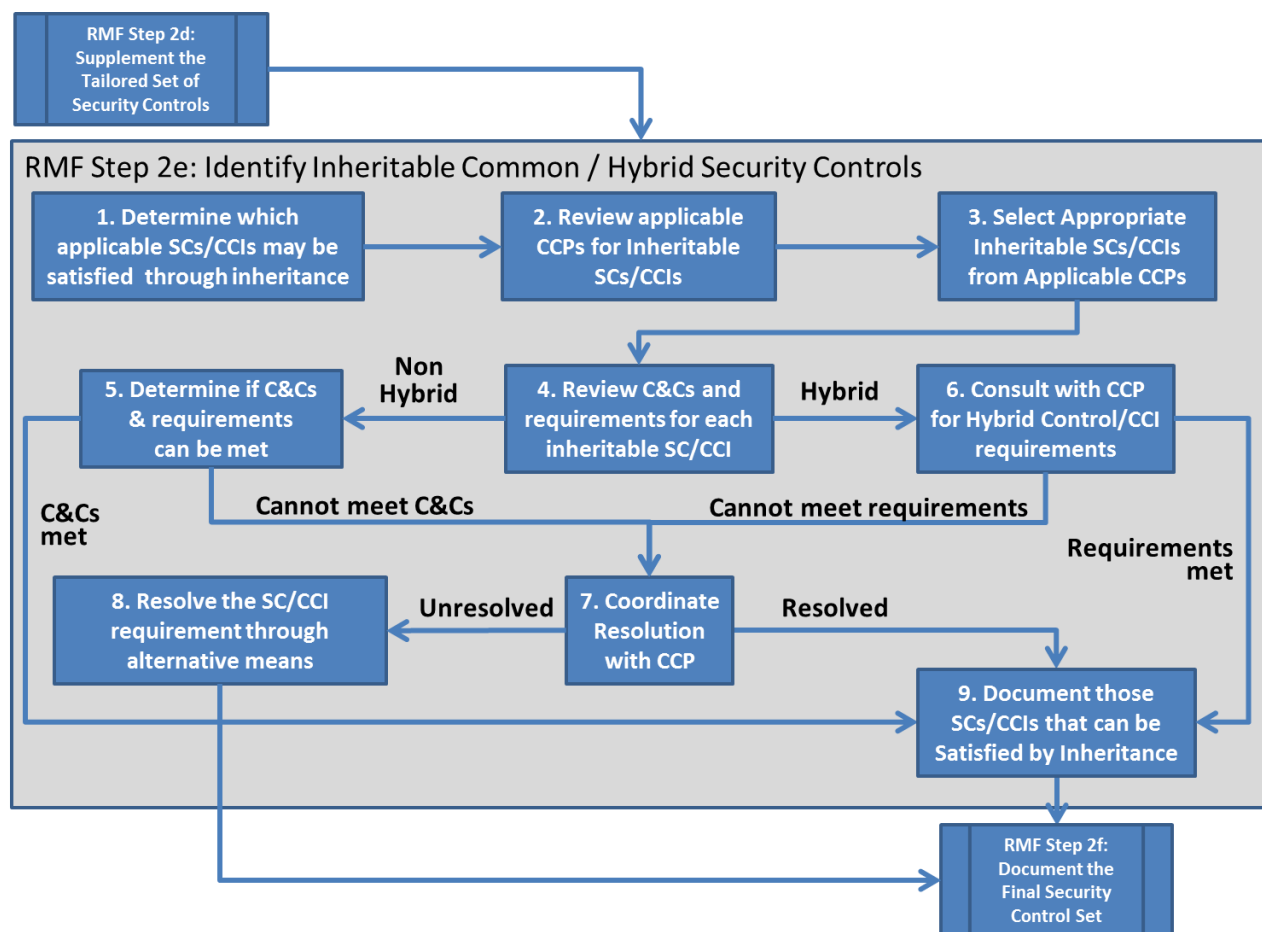
In some cases, it is possible to inherit the non-compliance of a security control and their associated from a provider. If the inheriting IS cannot satisfy a control internally, it may be required to use inheritance to achieve compliance. If the inheriting IS decides to inherit a control, the IS must make sure the satisfaction of the control can be met through inheritance. Just as successful satisfaction of a control can be achieved through inheriting a compliant control; it is also possible to inherit non-compliance as well. The non-compliance details will be found in the inheritance provider's eMASS package.

#### **7.2.6 RMF Step 2e: Identify Inheritable Common / Hybrid Security Controls**

RMF Step 2e is a crucial step in inheritance. To be successful, the inheriting entity must pay close attention to the requirements in this process.

**Note:** Though RMF Step 2e calls for identifying inheritable common and hybrid security controls, this also includes all those appropriate and associated inheritable CCIs.

Figure 4 depicts the process in RMF Step 2e – Identify Inheritable Common / Hybrid Security Controls.



**Figure 4. RMF Step 2e Identify Inheritable Common / Hybrid Security Controls**

**Note:** CCP/CIPs are also ISs and must follow these steps to identify the SCs and CCIs they plan to inherit from the CCP/CIPs they connect to.

#### 7.2.6.1 Step 2e 1. - Determine which applicable security controls (SCs) and CCIs may be satisfied through inheritance

The inheriting entity must determine if any of the required security controls / CCIs can be satisfied through inheritance. This step begins with determining which controls / CCIs are available for inheritance from CCP/CIP. The security controls and CCIs available for inheritance are determined by reviewing the appropriate CCP/CIP eMASS authorization package and by contacting the responsible CCP/CIP.

#### 7.2.6.2 Step 2e 2. - Review applicable CCPs for inheritable SCs and CCIs

The inheriting IS must review the inheritable SCs and CCIs of all applicable CCP/CIP's. This is done following steps:

- Review the inheritable control's compliance, associated CCIs, the C&Cs, and requirements for hybrid controls in the appropriate CCP/CIP's eMASS authorization package or in the Navy Enterprise Security Control and CCI Inheritance Catalog.
- Contact the applicable CCP/CIP to validate the list of inheritable controls and CCIs, including criteria, conditions, and constraints

- Evaluate the infrastructure (physical facility) response to identify appropriate inheritable controls and CCIs. For each potential inheritable control / CCI:
  - Assess and evaluate that the available inheritable control and CCI meets the following objectives:
    - The inheritable control / CCI is appropriate to the system desiring to inherit the security control / CCI
    - The provider IS is currently in operation and available to the system desiring to inherit the security control / CCI
    - The provider IS is compliant with the applicable control / CCI requirement at the required security level for the system desiring to inherit the security control / CCI
    - Assess and verify that the scope of work necessary to implement the desired security control and CCI is feasible
- For each inheritable control and CCI that meets the above criteria
  - Add the verified inheritable control and CCIs to an inherited controls list for the system desiring to inherit the security control / CCI.

**Note:** If a control/CCI that the inheriting system wishes to inherit is not listed as inheritable, the inheriting system may contact the CCP/CIP to coordinate having a certain control provided as inheritable.

**Note:** If a Non-Compliant security control/CCI is inherited, the inheriting entity inherits that non-compliance.

**Note:** The CCP/CIP is not required to provide a control or CCI as inheritable that they have determined cannot be provided based on their security strategy, plan, and architecture.

#### **7.2.6.3 Step 2e 3. - Select appropriate inheritable SCS and CCIs from applicable CCPs**

Based on the review of the CCP/CIP's available inheritable SCs and CCIs, select those inheritable controls and CCIs based on the IS's security plan and strategy.

#### **7.2.6.4 Step 2e 4. - Review the C&Cs and requirements for each inheritable SC and CCI**

Meeting the C&Cs and requirements for an inheritable SC and CCI as designated by the CCP is a critical component for properly satisfying an inheritable control. For each selected inheritable control and CCI, the inheriting system must closely review the C&Cs and requirements for each of those controls and CCIs.

For Non-Hybrid SCs and CCIs, proceed to Step 2e 5 - "Determine if C&Cs can be met".

For Hybrid security controls, carefully review the requirements for the provider and the inheritor.

#### **7.2.6.5 Step 2e 5. – Determine if the C&Cs and Requirements can be met**

The inheriting system must determine if it can meet the C&Cs and any other requirements for inheritance for each control and CCI it is planning to inherit.

If the inheriting system can meet the C&Cs and requirements for the inheritable control and CCI(s), resolution is determined through the assessment process in RMF Step 4, and documented in the inheriting system's A&A package (Step 2e 9 – "Document those SCs / CCIs that can be satisfied by Inheritance").

If the inheriting system cannot meet the published C&Cs and/or the other requirements of the inheritable SC / CCI:

- Work with the appropriate CCP/CIP to establish alternative C&Cs/requirements for resolution (Step 2e 7).
- Attempt to identify another resource (e.g., CIP) who has attainable C&Cs
- Attempt to identify a strategy for compliance within your own system (vice inheriting from another system).
- If none of the proposed resolutions above are possible, the inheriting system must acknowledge non-compliance and mark the SC/CCI as non-compliant within the Security Package

**Note:** The CCP/CIP is not required to provide specific C&Cs or other requirements for inheritable controls and CCIs that they have determined cannot be provided based on their security strategy, plan, and architecture.

**Note:** C&Cs differ from those requirements of a hybrid control or CCI.

#### **7.2.6.6 Step 2e 6. - Consult With the CCP for Hybrid Control Requirements**

If a required inheritable SC is provided as a hybrid control, there are specific requirements that the CCP/CIP and inheriting system must satisfy together before that control can be successfully inherited and compliance of the control is completely met.

The CCP/CIP providing a hybrid control must clearly document the portion of the control or CCIs they will provide and the portions the inheriting IS must resolve. This is documented in the provider's eMASS authorization package and the Navy Enterprise Security Control and CCI Inheritance Catalog.

**Note:** Responsibility for compliance to a CCI may not be shared/divided between multiple entities. CCIs must be fulfilled by either the system or its CCP.

The inheriting system must consult with the CCP/CIP to determine the exact requirements for the inheriting system's portion of the control (CCIs). This coordination notifies the CCP/CIP that the inheriting system will be inheriting that control.

The inheriting system must meet their portions of the hybrid control (CCIs) for inheritance to be complete. This two part compliance is implemented in Step 3 of the RMF process. When successfully implemented, compliance of the control is assessed during Step 4 of the RMF process. A hybrid control is only compliant when a thorough assessment shows complete resolution of the controls requirements.

Unsuccessful resolution of the control's requirements requires the provider and inheriting system to work a resolution. If no resolution is achievable, the inheriting system must resolve the security control through internal solutions.

#### **7.2.6.7 Step 2e 7. - Coordinate Resolution with CCP**

If for any reason, the inheriting system cannot meet the C&Cs or other requirements for non-hybrid controls/CCIs or the requirements for hybrid controls/CCIs, the inheriting system should coordinate with the CCP/CIP to resolve the issue.

If a resolution is achieved with the CCP/CIP, the inheritor moves to documenting those security controls that can be satisfied by inheritance (Step 2e 9.)

If a resolution is not achieved with the CCP/CIP, the inheriting system moves to Step 2e 8 -. "Resolve the SC/CCI Requirements Through Alternative Means"

**7.2.6.8 Step 2e 8. – Resolve the SC/CCI Requirement Through Alternative Means**

If the CCIs, C&Cs and other requirements cannot be resolved with the CCP, the security control cannot be satisfied through inheritance, and the inheritor must determine another solution or accept non-compliance with that control.

**7.2.6.9 Step 2e9 – Document those security controls that can be satisfied by inheritance**

Record the results of the inheritance process, those security controls that can be satisfied by inheritance in the IS security documentation, to include:

- IS/Program Security Plan
- A&A documentation
- eMASS

**7.2.7 Step 2 Inheritance Output**

For the inheritance process, a main output of RMF Step 2 is an updated system security plan that includes an overview of inheritance relationships needed to ensure inheritance is properly executed throughout the system lifecycle.

**7.3 RMF Step 3 - Implement Security Controls**

In this step, inheritable and inherited controls are implemented similarly to any other security control with some exceptions.

Implementing security controls is a coordinated effort between the PM/ISO, ISSE, ISSM, and any other organizations and entities that provide input for the use of common and inheritable controls.

For CCPs, while implementing inheritable controls, the provider must ensure all required CCIs and C&Cs are verified and documented. The provider must be ready to establish inheritance agreements with any qualified (meets all CCIs and C&Cs) system planning to inherit their inheritable controls.

Prior to implementing any inheritable controls, the inheriting system must coordinate with the provider to ensure that the CCIs and C&Cs can be met. This coordination and any agreements for CCIs/C&Cs and hybrid controls must be documented in the system's SP.

If an inheriting system cannot meet the CCIs and C&Cs of an inheritable security control, the inheriting system cannot successfully inherit that control. It then becomes the responsibility of that system to determine an alternative solution for satisfying that control.

If the inherited security control is properly implemented (all CCIs resolved and C&Cs met), the inheriting system inherits the provider's system's validation procedures and the compliance with that control and CCIs. Note: This includes any non-compliance the provider may have with that control.

Once any inherited controls are implemented, compliance with the CCIs and C&Cs of each inherited control must be verified and documented. Inheritance agreements and CCI/C&C verification will be formally assessed by the Validator in RMF Step 4 – Assess Security Controls.

**7.4 RMF Step 4 - Assess Security Controls**

In this step, as with any security control, all inheritable and inherited controls, and associated CCIs are assessed. The Validator performing the security testing/assessment must take into consideration the special nature of inheritable and inherited security controls. Validators are expected to evaluate all inherited controls and their CCIs via the validation procedures as defined by the provider. This includes any inheritance agreements established between providers and inheritors. Specifically, for non-eMASS inheritances, the Validator must ensure both parties have formally agreed to the inheritance occurrence and that agreement is documented. This ensures that inheritance is not done informally without the provider knowing. Additionally, the Validator ensures that all CCIs and C&Cs of the inheritable security control are met by the inheriting system for proper inheritance of that control.

During the assessment of security controls, any inheritable and inherited security controls/CCIs determined to be non-compliant, the Validator ensures those weaknesses are documented in the Security Assessment Report (SAR) and the Risk Assessment Report (RAR). Additionally, these non-compliant inheritable and inherited controls must be included in the system's Plan of Action and Milestones (POA&M).

For inherited security controls, the providing system maintains assessment test results and supporting documentation and makes them available to the SCA on request. For common controls inherited from the enterprise, instructions for documenting compliance are provided on the RMF KS. The Validator maximizes the reuse of existing assessment (i.e., a leveraged authorization), and T&E documentation in their assessment of the system.

## **CCP**

Just like any other system, a CCP will have all system security controls assessed for the Authorization in this step. In addition, providers have special situations when providing controls as inheritable and those situations must be evaluated also.

Inherited Controls. It is expected that a CCP will inherit controls from higher tiers and other providers in the enterprise/enclave. This includes controls the system has inherited from another CCP. As with any other system, the Validator must look at all inheritance agreements established with the provider(s), as well as determining if all C&Cs are met for a proper inheritance.

Inheritable Controls. As a CCP, all security controls provided as inheritable must be evaluated by the Validator to determine if the proper inheritance environment is provided and all C&Cs are documented. The Validator must take the inheritors view of the inheritable control during the evaluation, ensuring all C&Cs are properly documented to ensure a successful inheritance is accomplished. Additionally, it is required that the provider defines and provides validation procedures for all inheritable controls, their C&Cs and CCIs to any inheriting system.

## **7.5 RMF Step 5 - Authorize System**

The NAO verifies and approves all inherited controls for a system before issuing an authorization. This will include reviewing all C&Cs and agreements (MOUs/MOAs) for all inherited controls.

For CCPs, the NAO verifies and approves all inheritable controls before issuing an authorization. This will include reviewing all C&Cs for each provided controls are proper for a successful inheritance occurrence.

Once the Authorization is obtain, the CCP system PM/ISO/ISSE must update the Common Controls Catalog to provide a list of inheritable controls and the C&Cs.

## **7.6 RMF Step 6 - Monitor Security Controls**

For any CCP and inheritance provider, the associated PM/ISO and ISSM of the system providing these protections are responsible for continuously monitoring their provided security controls. Frequency of monitoring will be based on the needs of the system providing the protection. The providing system PM/ISO and ISSM have a responsibility to inform the PM/ISOs and ISSMs of the inheriting systems of any changes, or anticipated changes, in the provided protection(s) as soon as they are identified. This allows inheriting systems the opportunity to arrange for alternative protection(s) if necessary.

The CCP and inheritance provider prepares an A&A package (to include Information Security Continuous Monitoring [ISCM] Strategy) comprising those security controls being provided. The CCP is responsible for the continuous monitoring of the security controls they are providing. The CCP describes in the ISCM Strategy the monitoring method and frequency of any common controls requiring additional monitoring. The CCP informs PM/ISOs and ISSMs inheriting protections of any changes or anticipated changes in the provided protection(s) as soon as they are identified to allow inheriting systems the opportunity to arrange for alternative protection(s) if necessary.

In addition to the CCP's monitoring requirements mentioned above, for hybrid security controls, the inheriting PM/ISO and ISSM describes the allocation of the protections used to comply with each hybrid security control and the monitoring strategy in the ISCM Strategy. The monitoring strategy can use the monitoring provided by the providing system and CCP for any protections they provide, but must incorporate measures to monitor protections inherent to the system itself. The inheriting system PM/ISO and ISSM documents in the ISCM Strategy when monitoring of inherited or common protections is deemed insufficient, and implement enhanced monitoring.

### **7.6.1 Annual Security Review**

All applicable security controls not identified for continuous monitoring are placed in the annual security review pool. Annually, one third of these remaining controls will be re-assessed, with the intent being that every control from the annual security review pool will be assessed at least once during each three-year cycle.

For inheritance, if any changes occur in inheritable controls, the CCP conducts remediation actions based on the results of ongoing monitoring activities, assessment of risk, and outstanding items in the POA&M.

The CCP reports the security status of the system (including the effectiveness of security controls employed within and inherited by the system) to the AO and other appropriate organizational officials on an ongoing basis in accordance with the monitoring strategy.

### **7.6.2 Decommissioning**

When a system is removed from operation, a number of RMF-related actions are required. Before decommissioning, any control inheritance relationships should be reviewed and assessed for impact.

## **8.0 Summary**

Implementation of inheritance across the Navy will enhance opportunities for reciprocity and type authorization, minimizing total costs and enabling transparency of testing for authorized systems. RMF allows opportunity to formalize the inheritance of security services, strengthen the enterprise security posture, stretch security dollars through common security protections, and create a smaller risk management footprint. For risk management to succeed at the Navy enterprise level, all Navy organizations must use a standard approach, principles, and practice for risk management processes and procedures. The NEIM, as adapted from the RMF, is a foundation for this effort.

Through adoption of the NEIM methodology, enterprise security services can be identified, standardized, catalogued, and adapted as requirements change. If the method for identifying security services, including parameters and conditions of use, is carefully considered and integrated into an enterprise governance structure, all service providers can leverage the same parameters and governance to identify security services at the enterprise, site, and enclave levels. A standard approach to identifying inheritable security services will also enable development of requirements and exploration into the benefit of automated elements.

**Appendix A - Acronyms**

|           |                                                                                 |
|-----------|---------------------------------------------------------------------------------|
| A&A       | Assessment and Authorization                                                    |
| ADNS      | Automated Digital Network Services                                              |
| AO        | Authorizing Official                                                            |
| CA        | Certification Authority                                                         |
| C&A       | Certification and Accreditation                                                 |
| C&C       | Conditions and Constraints                                                      |
| CANES     | Consolidated Afloat Networks and Enterprise Services                            |
| CCP       | Common Control Provider                                                         |
| CIO       | Chief Information Officer                                                       |
| CIP       | Critical Inheritance Provider                                                   |
| CND       | Computer Network Defense                                                        |
| CNSS      | Committee on National Security Systems                                          |
| CNSSI     | Committee on National Security Systems Instruction                              |
| COP       | Common Operational Picture                                                      |
| CYBERSAFE | Cybersecurity Safety                                                            |
| DFIA      | Defense in Depth Functional Implementation Architecture                         |
| DIACAP    | Defense Information Assurance Certification and Accreditation Process           |
| DISA      | Defense Information Systems Agency                                              |
| DITSCAP   | Defense Information Technology Security Certification and Accreditation Process |
| DoD       | Department of Defense                                                           |
| DoDI      | Department of Defense Instruction                                               |
| DON       | Department of the Navy                                                          |
| eMASS     | Enterprise Mission Assurance Support System                                     |
| FIPS      | Federal Information Processing Standards                                        |
| IS        | Information System                                                              |
| ISSE      | Information System Security Engineer                                            |
| ISSM      | Information System Security Manager                                             |
| ISSO      | Information System Security Officers                                            |
| KS        | Knowledge Service                                                               |
| MOA       | Memorandum of Agreement                                                         |
| MOU       | Memorandum of Understanding                                                     |

|         |                                                |
|---------|------------------------------------------------|
| NAO     | Navy Authorizing Official                      |
| NAVSEA  | Naval Sea Systems Command                      |
| NC      | Non-compliant                                  |
| NEIM    | Navy Enterprise Inheritance Model              |
| NIST    | National Institute of Standards and Technology |
| NIST SP | NIST Special Publication                       |
| NMCI    | Navy Marine Corps Intranet                     |
| OCONUS  | Outside Continental United States              |
| ODNI    | Office of the Director of Naval Intelligence   |
| ONENET  | Navy Enterprise Network                        |
| PIT     | Platform Information Technology                |
| PKI     | Public Key Infrastructure                      |
| PM      | Program Manager                                |
| RMF     | Risk Management Framework                      |
| SCA     | Security Controls Assessor                     |
| SISO    | Senior Information Security Officer            |
| SLA     | Service Level Agreement                        |
| SP      | Special Publication                            |
|         | Security Plan                                  |
| SPAWAR  | Space and Naval Warfare Systems Command        |
| T&E     | Test and Evaluation                            |
| USN     | United States Navy                             |

## **Appendix B – References**

- a. NIST 800-53, Current Revision, Security and Privacy Controls for Federal Information Systems and Organizations
- b. DoDI 8510.01, RMF for DoD Information Technology (IT)
- c. NIST SP 800-37, Guide for Applying the Risk Management Framework to Federal Information Systems: a Security Life Cycle Approach
- d. CNSSI 1253, Security Categorization and Control Selection for National Security Systems,
- e. CNSSI 4009, Committee on National Security Systems (CNSS) Glossary
- f. FIPS 199, Standards for Security Categorization of Federal Information and Information Systems
- g. NIST 800-30, Guide for Conducting Risk Assessments
- h. Risk Management Framework Process Guide, Navy Authorizing Official and Security Controls Assessor, Version 1.0, 13 December 2016
- i. Department of Defense (DoD) Risk Management Framework (RMF) Knowledge Service (KS)
- j. SECNAV Instruction 5239.3C, Department of the Navy Cybersecurity Policy
- k. DoD Cloud Computing Security, Cloud Computing Security Requirements Guide (CC SRG)

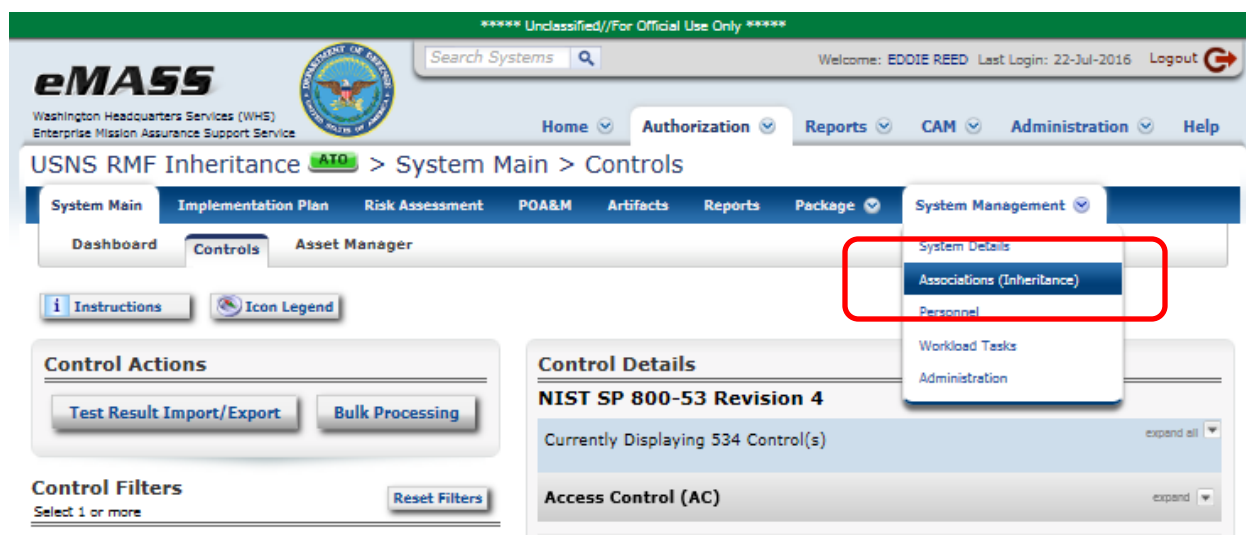
## Appendix C – eMASS Associations (Inheritance)

### 1.0 Navy enterprise inheritance depends on the associations created in eMASS. Overview Of Associations (Inheritance):

- Inheritance is established the same way whether it is within the same instance of eMASS or with another service or agency. Currently links are active between the Navy instance and Army, Joint Staff, DISA, USAF, and DFAS.
- Users set up the system inheritance, typically performed just after system registration, depending on the number and type of information systems already registered in eMASS.
- Inheritance identifies authorization boundaries and creates relationships (i.e. Parent/Child or Co-System) between interconnected information.
- eMASS provides multiple views for managing inheritance which are located under Inheritance Options.
- Users have the ability to establish an inheritance relationship to where an individual security control is inherited from multiple providers.
- When inheritance is established, a receiving system will have visibility into all the test results from inherited controls and artifacts associated to the inherited control.
- Users can manage the systems Common Control Provider and Assessment Only relationships within the Associations Summary.

### 2.0 Procedures

2.1 To View or Manage Associations select “Associations (Inheritance)” from the “System Management” drop down menu:



2.2 The “Associations Summary” tab displays a listing of all currently approved associations (receiving and providing):

Navy Reserve Order Writing System Not Yet Authorized > System Management > Associations > Associations Summary

System Main Implementation Plan Risk Assessment POA&M Artifacts Reports Package System Management

Associations Summary Control Summary Requests & Approvals (0)

RMF DIACAP

Instructions

Receiving Inheritance Relationships (1)

Manage Common Control Providers

| Providing System Acronym                     | Providing System Owner | Providing System ID | Controls Inherited | APs Inherited | System Type          | Authorization Status           | Authorization Termination Date | Date Established |
|----------------------------------------------|------------------------|---------------------|--------------------|---------------|----------------------|--------------------------------|--------------------------------|------------------|
| <a href="#">Tier 1 - DoD RMF Inheritance</a> | USN                    | 8256                | 0                  | 414           | IS Major Application | Authorization to Operate (ATO) | 17-May-2018                    | 06-Oct-2015      |

Providing Inheritance Relationships (70)

| Receiving System Acronym | Receiving System Owner | Receiving System ID | Controls Inherited | System Type        | Authorization Status                   | Authorization Termination Date | Date Established |
|--------------------------|------------------------|---------------------|--------------------|--------------------|----------------------------------------|--------------------------------|------------------|
| <a href="#">3SP</a>      | NDW - Platform IT      | 7418                | 0                  | Platform IT System | Expired Authorization to Operate (ATO) | 29-Sep-2015                    | 09-Jun-2015      |
| <a href="#">AIM4RMC</a>  | NAVSEA                 | 8265                | 23                 | IS Enclave         | Authorization to Operate (ATO)         | 30-Nov-2016                    | 08-Jun-2015      |
| <a href="#">AMES-RMF</a> | NAVSEA-AODR-RDT&E      | 8345                | 0                  | IS Enclave         | Not Yet Authorized                     |                                | 09-Jun-2015      |

2.3 The “Requests & Approvals” screen allows users to approve, request or pre-approve Inheritance relationships:

Tier 1 - DoD RMF Common Control & Automatically Compliant Assessment Procedures ATO > System Management > Associations > Requests & Approvals

| System Main                                        | Implementation Plan | Risk Assessment               | POA&M               | Artifacts                      | Reports                  | Package                        | System Management                 |                          |  |  |  |  |  |
|----------------------------------------------------|---------------------|-------------------------------|---------------------|--------------------------------|--------------------------|--------------------------------|-----------------------------------|--------------------------|--|--|--|--|--|
| Associations Summary                               | Control Summary     | Requests & Approvals (1)      |                     |                                |                          |                                |                                   |                          |  |  |  |  |  |
| Instructions  Filter                               |                     |                               |                     |                                |                          |                                |                                   |                          |  |  |  |  |  |
| Awaiting Approval - Systems Requesting Inheritance |                     |                               |                     |                                |                          |                                |                                   |                          |  |  |  |  |  |
| System Acronym                                     | System ID           | Information System Owner      | Date Requested      | Confirm                        | Deny                     | Comments                       |                                   |                          |  |  |  |  |  |
| CKTM                                               | 9041                | FLTCYBERCOM                   | 29-Jan-2016         | <input type="checkbox"/>       | <input type="checkbox"/> |                                |                                   |                          |  |  |  |  |  |
|                                                    |                     |                               |                     |                                |                          |                                |                                   |                          |  |  |  |  |  |
| Request or Pre-Approve Inheritance                 |                     |                               |                     |                                |                          |                                |                                   |                          |  |  |  |  |  |
| Now Showing: My Instance                           |                     |                               |                     |                                |                          |                                |                                   |                          |  |  |  |  |  |
| System Acronym                                     | System ID           | System Name                   | System Organization | Authorization Status           | System Type              | Authorization Termination Date | Grant Select Visible              | Request Select Visible   |  |  |  |  |  |
| 3SP                                                | 7418                | Shore Sensor Systems Platform | NDW - Platform IT   | Authorization to Operate (ATO) | Platform IT System       | 29-Sep-2015                    | Approved <input type="checkbox"/> | <input type="checkbox"/> |  |  |  |  |  |

2.3.1 To request inheritance from another instance of eMASS, click the [Filter] button:

Tier 1 - DoD RMF Common Control & Automatically Compliant Assessment Procedures ATO >  
System Management > Associations > Requests & Approvals

System Main Implementation Plan Risk Assessment POA&M Artifacts Reports Package System Management

Associations Summary Control Summary **Requests & Approvals (1)**

[Instructions](#) [Filter](#)

### Awaiting Approval - Systems Requesting Inheritance

| System Acronym | System ID | Information System Owner | Date Requested | Confirm                  | Deny                     | Comments |
|----------------|-----------|--------------------------|----------------|--------------------------|--------------------------|----------|
| CKTM           | 9041      | FLTCYBERCOM              | 29-Jan-2016    | <input type="checkbox"/> | <input type="checkbox"/> |          |

[Save](#) [Cancel](#)

### Request or Pre-Approve Inheritance

Now Showing: My Instance

| System Acronym | System ID | System Name                   | System Organization | Authorization Status           | System Type        | Authorization Termination Date | Grant Select Visible | Request Select Visible   |
|----------------|-----------|-------------------------------|---------------------|--------------------------------|--------------------|--------------------------------|----------------------|--------------------------|
| 3SP            | 7418      | Shore Sensor Systems Platform | NDW - Platform IT   | Authorization to Operate (ATO) | Platform IT System | 29-Sep-2015                    | Approved             | <input type="checkbox"/> |

2.3.2 Select the instance of eMASS you wish to inherit from and provide any other search criteria you want, then click the [Filter] button:

Tier 1 - DoD RMF Common Control & Automatically Compliant Assessment Procedures **ATO** >  
System Management > Associations > Requests & Approvals

System Main Implementation Plan Risk Assessment POA&M Artifacts Reports Package System Management

Associations Summary Control Summary **Requests & Approvals (1)**

**eMASS Inheritance Filter**

**\* eMASS Instance:** **My Instance**  
 System Name: Joint Staff  
 USAF  
 DISA  
 DFAS

Organization:   
 System Acronym:

Authorization Status:  
☐ Has ATO ☐ Not Yet Authorized  
☐ Has DATO ☐ Has IATT  
☐ Has ATO w/ Conditions

**Filter** **Reset**

| System Acronym | System ID | System Name                 | System Organization | Authorization Status           | System Type        | Authorization Termination Date | Grant Select Visible | Request Select Visible   |
|----------------|-----------|-----------------------------|---------------------|--------------------------------|--------------------|--------------------------------|----------------------|--------------------------|
| 3SP            | 7418      | Shore Sensor Systems Platom | NDW - Platform IT   | Authorization to Operate (ATO) | Platform IT System | 29-Sep-2015                    | Approved             | <input type="checkbox"/> |

2.4 A listing of systems from the selected eMASS instance will appear. Here you can Pre-Approve inheritance to a system or request inheritance from a system:

| Request or Pre-Approve Inheritance |           |                                                        |                     |                                |                      |                                |                          |                          |
|------------------------------------|-----------|--------------------------------------------------------|---------------------|--------------------------------|----------------------|--------------------------------|--------------------------|--------------------------|
| Now Showing: Army                  |           |                                                        |                     |                                |                      |                                |                          |                          |
| System Acronym                     | System ID | System Name                                            | System Organization | Authorization Status           | System Type          | Authorization Termination Date | Grant Select Visible     | Request Select Visible   |
| 1ST ARMY VS-SAN NIPR               | 1195      | 1ST ARMY VIRTUAL SYSTEMS AND STORAGE AREA NETWORK NIPR | 1st Army            | Not Yet Authorized             | IS Major Application | -                              | <input type="checkbox"/> | <input type="checkbox"/> |
| 2RCC CONUS TLA                     | 77        | 2RCC CONUS TOP LEVEL ARCHITECTURE                      | NETCOM              | Authorization to Operate (ATO) | IS Enclave           | 05-Nov-2015                    | <input type="checkbox"/> | <input type="checkbox"/> |
| 2RCC REGIONAL TLA                  | 1213      | 2RCC REGIONAL TOP LEVEL ARCHITECTURE                   | NETCOM              | Not Yet Authorized             | IS Enclave           | -                              | <input type="checkbox"/> | <input type="checkbox"/> |
| 4DWX                               | 1399      | Four-Dimensional Weather System                        | ATEC                | Not Yet Authorized             | IS Major Application | -                              | <input type="checkbox"/> | <input type="checkbox"/> |

2.5 The “Control Summary” section allows users to make Security control(s) inheritable. To make a control inheritable click the [Edit] button:

Navy Reserve Order Writing System Not Yet Authorized > System Management > Associations > Control Summary

System Main Implementation Plan Risk Assessment POA&M Artifacts Reports Package System Management

Associations Summary **Control Summary** Requests & Approvals (0) RMF DIACAP

Instructions

**Control Summary**

★ Common Control Provider: No

**Access Control (AC)** expand

**Authority And Purpose (AP)** None

**Accountability, Audit, And Risk Management (AR)** None

2.6 Set a control to be “Manually” inherited click on the “Establish Manual Inheritance” Hyperlink (Manual Inheritance used to be called “External Inheritance”):

Identification and Authentication (IA) expand

**eMASS**

**Planning (PL)**

| Control   |                                                                                                      | Inheritable<br>Select All<br>Controls <input type="checkbox"/><br>APs <input type="checkbox"/> | Provided By<br>Default<br>Select All<br>Controls <input type="checkbox"/><br>APs <input type="checkbox"/> |          |
|-----------|------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------|----------|
| B PL-1    | Security Planning Policy And Procedures<br><a href="#">Establish Manual Inheritance</a>              | <input checked="" type="checkbox"/>                                                            | <input checked="" type="checkbox"/>                                                                       | expand   |
| B PL-2    | System Security Plan<br><a href="#">Establish Manual Inheritance</a>                                 | <input type="checkbox"/>                                                                       | <input type="checkbox"/>                                                                                  | expand   |
| B PL-2(3) | Plan / Coordinate With Other Organizational Entities<br><a href="#">Establish Manual Inheritance</a> | <input type="checkbox"/>                                                                       | <input type="checkbox"/>                                                                                  | collapse |
| AP        | CCI                                                                                                  | Select All<br><input type="checkbox"/>                                                         | Select All<br><input type="checkbox"/>                                                                    |          |
| PL-2(3).1 | 003065                                                                                               | <input type="checkbox"/>                                                                       | <input type="checkbox"/>                                                                                  |          |
| PL-2(3).2 | 003067                                                                                               | <input type="checkbox"/>                                                                       | <input type="checkbox"/>                                                                                  |          |
| B PL-4    | Rules Of Behavior<br><a href="#">Establish Manual Inheritance</a>                                    | <input type="checkbox"/>                                                                       | <input type="checkbox"/>                                                                                  | expand   |

Save Cancel

System and Information Integrity (SI)

2.7 Provide the Information System Owner, Originating Information System and the Control Compliance Status and Comments. Click the “Add Test Results” to add APs test results (not optional), click “Add Artifact” if you wish to add optional Artifacts. Click [Save] to store the information

eMASS RMF System [ATO w/Conditions](#) > Associations > Manually Document Inheritance

System Main Implementation Plan Risk Assessment POA&M Artifacts Reports Package System Management

Associations Summary Control Summary Requests & Approvals (0)

[Instructions](#)

**Control Acronym:** AC-1  
**Control Name:** Access Control Policy And Procedures

★ **Information System Owner:** Marine Corps

★ **Originating Information System:** CBC

★ **Control Compliance Status:** Compliant  
 Inheriting common access controls from the Endave

★ **Comments:**

Add Test Results ☐

Add Artifact ☐

[Save](#) [Cancel](#)

2.8 Once a system is receiving an inheritance relationship, the user must select the Controls and assessment procedures to inherit. From the Associations Summary Screen click the [Providing System Acronym] hyperlink in the Receiving Inheritance Relationships table:

Navy Reserve Order Writing System [Not Yet Authorized](#) > System Management > Associations > Associations Summary

System Main Implementation Plan Risk Assessment POA&M Artifacts Reports Package System Management

Associations Summary Control Summary Requests & Approvals (0) [RMF](#) [DIACAP](#)

[Instructions](#)

**Receiving Inheritance Relationships (1)** [Manage Common Control Providers](#)

| Providing System Acronym                     | Providing System Owner | Providing System ID | Controls Inherited | APs Inherited | System Type          | Authorization Status           | Authorization Termination Date | Date Established |
|----------------------------------------------|------------------------|---------------------|--------------------|---------------|----------------------|--------------------------------|--------------------------------|------------------|
| <a href="#">Tier 1 - DoD RMF Inheritance</a> | USN                    | 8256                | 0                  | 414           | IS Major Application | Authorization to Operate (ATO) | 17-May-2018                    | 06-Oct-2015      |

**Providing Inheritance Relationships (70)**

| Receiving System Acronym | Receiving System Owner | Receiving System ID | Controls Inherited | System Type        | Authorization Status                   | Authorization Termination Date | Date Established |
|--------------------------|------------------------|---------------------|--------------------|--------------------|----------------------------------------|--------------------------------|------------------|
| <a href="#">3SP</a>      | NDW - Platform IT      | 7418                | 0                  | Platform IT System | Expired Authorization to Operate (ATO) | 29-Sep-2015                    | 09-Jun-2015      |
| <a href="#">AIM4RMC</a>  | NAVSEA                 | 8265                | 23                 | IS Enclave         | Authorization to Operate (ATO)         | 30-Nov-2016                    | 08-Jun-2015      |
| <a href="#">AMES-RMF</a> | NAVSEA-AODR-RDT&E      | 8345                | 0                  | IS Enclave         | Not Yet Authorized                     |                                | 09-Jun-2015      |

**2.9** A list of all controls and assessment procedures that can be inherited from the providing system are displayed. Place a check in the checkbox next to the controls and assessment procedures to be inherited. Click [Save] when done:

**Receiving Inheritance Relationship - System Detail View: Tier 1 - DoD RMF Inheritance**

|                                                                                                                                                                                                                                      |                                                                                                                           |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------|
| Providing System Acronym                                                                                                                                                                                                             | <b>Tier 1 - DoD RMF Inheritance</b>                                                                                       |
| Providing System Name                                                                                                                                                                                                                | <b>Tier 1 - DoD RMF Common Control &amp; Automatically Compliant Assessment Procedures</b>                                |
| Providing System Identification Number                                                                                                                                                                                               | <b>8256</b>                                                                                                               |
| Providing Information System Owner                                                                                                                                                                                                   | <b>USN</b>                                                                                                                |
| Providing System Description                                                                                                                                                                                                         | <b>This eMASS record supports inheritance of Common Controls &amp; any automatically compliant Assessment Procedures.</b> |
| Providing System Authorization Status                                                                                                                                                                                                | <b>Authorization to Operate (ATO)</b>                                                                                     |
| Providing Authorization Termination Date                                                                                                                                                                                             | <b>17-May-2018</b>                                                                                                        |
| Date Inheritance Established                                                                                                                                                                                                         | <b>06-Oct-2015</b>                                                                                                        |
| System Type                                                                                                                                                                                                                          | <b>IS Major Application</b>                                                                                               |
| Total Number of Inherited Controls                                                                                                                                                                                                   | <b>0</b>                                                                                                                  |
| Total Number of Shared Controls                                                                                                                                                                                                      | <b>171</b>                                                                                                                |
| Total Number of Inherited APs                                                                                                                                                                                                        | <b>414</b>                                                                                                                |
| <div style="display: inline-block; border: 1px solid #ccc; padding: 5px; margin: 5px;">Remove Inheritance Relationship</div> <div style="display: inline-block; border: 1px solid #ccc; padding: 5px; margin: 5px;">Force Sync</div> |                                                                                                                           |

| <b>NIST SP 800-53 Revision 4</b> |                                      |                   |              | Number of Inherited Controls:0             | collapse                 |
|----------------------------------|--------------------------------------|-------------------|--------------|--------------------------------------------|--------------------------|
| <b>Access Control</b>            |                                      |                   |              | Number of Shared Controls:21               |                          |
|                                  |                                      |                   |              | Number of Inherited APs:38                 |                          |
|                                  |                                      |                   |              | Select All Controls in this Control Family | <input type="checkbox"/> |
|                                  |                                      |                   |              | Select All APs in this Control Family      | <input type="checkbox"/> |
| Acronym                          | Name                                 | Compliance Status | Organization | Select                                     |                          |
| AC-1                             | Access Control Policy And Procedures | Non-Compliant     |              | <input type="checkbox"/>                   | collapse                 |
|                                  |                                      |                   |              | Select All APs in this Control             | <input type="checkbox"/> |
| Acronym                          | Name / CCI #                         |                   |              | Select                                     |                          |
| AC-1.1                           | CCI #: 002107                        |                   |              | <input checked="" type="checkbox"/>        |                          |
| AC-1.2                           | CCI #: 002108                        |                   |              | <input checked="" type="checkbox"/>        |                          |
| AC-1.3                           | CCI #: 000001                        |                   |              | <input type="checkbox"/>                   |                          |

**2.10** The Receiving System Details will be updated with the number of controls and assessment procedures chosen to be inherited

Remove Inheritance Relationship button will delete the association

Force Sync will bring the relationship current

**Receiving Inheritance Relationship - System Detail View: Tier 1 - DoD RMF Inheritance**

|                                          |                                                                                                                           |
|------------------------------------------|---------------------------------------------------------------------------------------------------------------------------|
| Providing System Acronym                 | <b>Tier 1 - DoD RMF Inheritance</b>                                                                                       |
| Providing System Name                    | <b>Tier 1 - DoD RMF Common Control &amp; Automatically Compliant Assessment Procedures</b>                                |
| Providing System Identification Number   | <b>8256</b>                                                                                                               |
| Providing Information System Owner       | <b>USN</b>                                                                                                                |
| Providing System Description             | <b>This eMASS record supports inheritance of Common Controls &amp; any automatically compliant Assessment Procedures.</b> |
| Providing System Authorization Status    | <b>Authorization to Operate (ATO)</b>                                                                                     |
| Providing Authorization Termination Date | <b>17-May-2018</b>                                                                                                        |
| Date Inheritance Established             | <b>06-Oct-2015</b>                                                                                                        |
| System Type                              | <b>IS Major Application</b>                                                                                               |
| Total Number of Inherited Controls       | <b>0</b>                                                                                                                  |
| Total Number of Shared Controls          | <b>171</b>                                                                                                                |
| Total Number of Inherited APs            | <b>414</b>                                                                                                                |
|                                          | <a href="#">Remove Inheritance Relationship</a>                                                                           |
|                                          | <a href="#">Force Sync</a>                                                                                                |

**Appendix D - Inheriting Security Controls in eMASS**

*Under development*

**Appendix E – Inheritance Overlay**

*Under development*